

UNIDAD NRO. 2

ADMINISTRACIÓN DE RECURSOS EN ÁREAS DE SISTEMAS DE INFORMACIÓN

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

UNIDAD 2: ADMINISTRACIÓN DE RECURSOS EN ÁREAS DE SISTEMAS DE INFORMACIÓN

Diseño Curricular de la Carrera de Ingeniería en Sistemas de Información

Plan 2023 - Ordenanza 1877

Contenidos Mínimos s/Ordenanza

Administración de los recursos asociados a los Sistemas de Información, Software y Comunicación.

OBJETIVOS s/Ordenanza

Aplicar técnicas y metodologías en la elaboración del plan estratégico en la **selección y dirección de** talento y capital humano, **procesos y sistemas software, sistemas de computación y comunicación en áreas** y proyectos de sistemas de Información, considerando los riesgos y optimizando los recursos tecnológicos.

COMPETENCIAS RELACIONADAS a la asignatura

Competencias específicas de la carrera:

CE1.1: **Especificar**, proyectar y desarrollar sistemas de información para **concebir** soluciones tecnológicas que permitan resolver situaciones en las organizaciones mediante el empleo de metodologías de sistemas y tecnologías asociadas a los sistemas de información.

CE5.1: **Dirigir y controlar** la implementación, operación y mantenimiento de sistemas de información, sistemas de comunicación de datos, software, seguridad informática y calidad de software, a los fines de alcanzar los objetivos fijados por la organización

Competencias genéricas de la carrera:

Competencias Tecnológicas

CG1: Identificar, formular y resolver problemas de ingeniería.

CG2: Concebir, diseñar y desarrollar proyectos de ingeniería.

CG3: Gestionar, planificar, ejecutar y controlar proyectos de ingeniería.

CG4: Utilizar de manera efectiva las técnicas y herramientas de aplicación en la ingeniería.

CG5: Contribuir a la generación de desarrollos tecnológicos y/o innovaciones tecnológicas.

– Competencias Sociales Políticas y Actitudinales

CG6: Desempeñarse de manera efectiva en equipos de trabajo.

CG7: Comunicarse con efectividad.

CG8: Actuar con ética, responsabilidad profesional y compromiso social, considerando el impacto económico, social y ambiental de su actividad en el contexto local y global.

CG9: Aprender en forma continua y autónoma.

CG10: Actuar con espíritu emprendedor.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

RESULTADO DE APRENDIZAJE Y CAPACIDADES RELACIONADAS DEFINIDAS PARA LAS UNIDADES 1 Y 2:

Diseñar un plan estratégico de tecnologías de la información y la comunicación alineado a las metas y objetivos organizacionales

Capacidades:

- Analizar Sistémicamente una organización de forma tal de reconocer los procesos críticos de la misma y los recursos asociados a los sistemas de información, software y comunicación que los sustentan
- Identificar metas organizacionales y alinear objetivos de TI a las mismas
- Identificar los riesgos a los que están sometidos los activos de información en diferentes contextos organizacionales
- Especificar indicadores de rendimiento y riesgos
- Asociar posibles soluciones para la gestión de servicios de tecnologías de la información a partir de la situación analizada, las debilidades/amenazas identificadas en función de optimizar los recursos tecnológicos existentes
- Plantear mecanismos de control en el contexto identificado y las posibles soluciones

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****ÍNDICE**

INTRODUCCIÓN.....	1
BUENAS PRÁCTICAS EN SEGURIDAD DE LA INFORMACIÓN	2
COBIT 2019	4
ISO 31000: 2018: GESTIÓN DEL RIESGO. DIRECTRICES	4
MAGERIT V.3.	5
SERIE ISO 27000	5
EL PROCESO DE GESTIÓN DE RIESGOS	7
RECOPILAR DATOS	8
IDENTIFICACIÓN DE ACTIVOS	8
IDENTIFICACIÓN DE AMENAZAS Y VULNERABILIDADES.....	10
TAXONOMÍAS PARA LA IDENTIFICACIÓN DE RIESGOS	11
ANALIZAR EL RIESGO	13
VALORACIÓN DE LOS RIESGOS.....	13
PRIORIZACIÓN PARA EL TRATAMIENTO DE LOS RIESGOS	15
RESPONDER A LOS RIESGOS.....	16
ESTRATEGIAS DE TRATAMIENTO DE LOS RIESGOS.....	16
PLANES DE CONTINGENCIA, RECUPERACIÓN Y CONTINUIDAD DE NEGOCIO	19
GESTIÓN DE SERVICIOS EN TECNOLOGÍAS DE INFORMACIÓN	21
INTRODUCCIÓN	21
CONCEPTOS DE LA GESTIÓN DE SERVICIOS DE TI (ITSM).....	22
SERVICIO	22
CALIDAD DEL SERVICIO.....	22
VALOR DEL SERVICIO	23
ACTIVOS DEL SERVICIO.....	24
ADMINISTRACIÓN DE LA RELACIÓN CON EL CLIENTE	24
GESTIÓN DE SERVICIOS BASADA EN PROCESOS	25
FUNDAMENTOS DE LA GESTIÓN DE SERVICIOS DE TI BASADOS EN ITIL.....	25
PRÁCTICAS DE ITIL 4.....	28
GESTIÓN DE INCIDENTES.....	29
ACTIVIDADES DE LA GESTIÓN DE INCIDENTES.....	29
GESTIÓN DE SOLICITUDES DE SERVICIO	32
ACTIVIDADES DE LA GESTIÓN DE SOLICITUDES DE SERVICIO	32
CENTRO DE SERVICIOS DE TI.....	33
GESTIÓN Y MONITORIZACIÓN DE EVENTOS	35
ACTIVIDADES DEL LA GESTIÓN Y MONITORIZACIÓN DE EVENTOS.....	36
GESTIÓN DE PROBLEMAS	37
ACTIVIDADES DE LA GESTIÓN DE PROBLEMAS	38
CONTROL DE CAMBIOS.....	40
ACTIVIDADES DEL CONTROL DE CAMBIOS:	40
GESTIÓN DE LA CONFIGURACIÓN DEL SERVICIO Y GESTIÓN DE ACTIVOS DE TI.....	43
ACTIVIDADES DE LA GESTIÓN DE LA CONFIGURACIÓN DEL SERVICIO	43
ACTIVIDADES DE LA GESTIÓN DE ACTIVOS DE TI.....	44
GESTIÓN DE VERSIONES.....	45
ANEXOS	47
ANEXO I: PROCESO RELACIONADO AL OBJETIVO GESTIONAR RIESGOS DE COBIT 2019	47
ANEXO II: ETAPAS DE UN CIBERATAQUE	50

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****INTRODUCCIÓN**

En la Unidad 1 hemos analizado brevemente el marco de COBIT 2019 como una de las buenas prácticas vinculadas al Gobierno y Gestión de las Tecnologías de Información.

De lo analizado se ha indicado que el Sistema de Gobierno de TI se encarga de evaluar, dirigir y monitorizar (EDM), en función de los siguientes objetivos:

- Asegurar el establecimiento y mantenimiento del Marco de Gobierno
- Asegurar la Obtención de Beneficios
- Asegurar la Optimización del Riesgo
- Asegurar la Optimización de los Recursos
- Asegurar el compromiso de las partes interesadas

Además, y en relación al Plan Estratégico de Tecnologías de la Información (PETI), se han evaluado las primeras acciones para su elaboración, entre ellas, comprender el contexto de la organización y el entorno de TI y establecer objetivos estratégicos relacionados con el análisis ambiental, identificando oportunidades y amenazas, y organizacional, identificando fortalezas y debilidades.

El Gobierno de TI requerirá de información referida a la evolución del PETI en términos de indicadores que le permitan analizar el cumplimiento de objetivos.

Para esto, nos concentraremos en esta unidad en los objetivos del dominio de Gobierno TI: Optimización del Riesgo y de los Recursos.

Para el primer objetivo, ampliaremos el concepto de riesgos de TI mencionado en la Unidad 1, lo que nos lleva a introducirnos en el tema de Seguridad de la Información para comprender la Gestión de Riesgos en este contexto.

Para el segundo nos concentraremos en los Procesos de Gestión de TI requeridos para la administración eficiente y eficaz de los recursos de TI.

En ambos casos deberemos tener el foco en mantener la continuidad de los procesos críticos y claves de la organización, es decir, la continuidad del negocio en todo lo que respecta a los procesos de soporte que refieren a las TI.



BUENAS PRÁCTICAS EN SEGURIDAD DE LA INFORMACIÓN

La seguridad de la información es el proceso de planear, organizar, coordinar, dirigir y controlar las actividades relacionadas a asegurar la seguridad de la información de una organización en todas sus dimensiones: integridad, confidencialidad y disponibilidad.

Integridad de la Información: que la misma solo pueda ser modificada por las entidades autorizadas y minimizando las posibilidades de corrupción por fallas físicas o lógicas, de hardware o software, malware o alteraciones causadas por usuarios internos o intrusos con el fin de causar daño o sin intención. Es decir, ***mantener la exactitud y completitud de la información y sus métodos de proceso.***

Confidencialidad de la Información: es la característica en cuanto a su almacenamiento y transmisión que posibilita que la misma sea conocida y manipulada sólo por personas autorizadas. Este principio se aplica a los datos personales y a los datos sensibles que pueden residir en las bases de datos de las empresas y se dan en las relaciones de las compañías con sus empleados y clientes, los datos médicos, en el ámbito jurídico, entre otros escenarios. Es decir: ***garantizar la privacidad de la información y de su tratamiento, para prevenir su divulgación no autorizada cuando está almacenada o en tránsito.*** Esta dimensión se apoya en el principio de “no repudio” que es la capacidad de demostrar o probar la participación de las partes (origen y destino, emisor y receptor, remitente y destinatario), mediante su identificación, en una comunicación o en la realización de una determinada acción. Para garantizar el no repudio en seguridad informática se necesitan establecer los siguientes mecanismos de identificación, autenticación y trazabilidad.



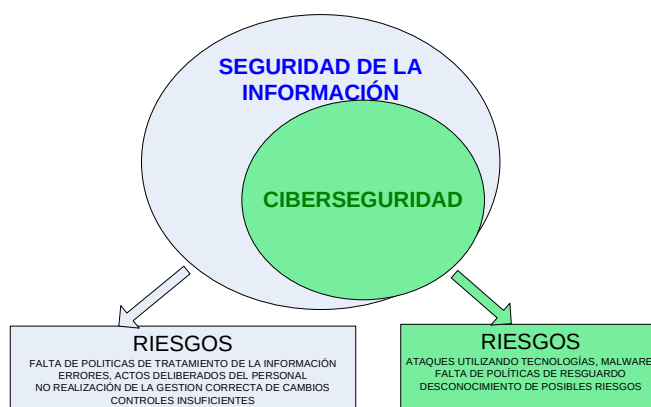
Disponibilidad de la información: ***garantizar que los recursos (información, sistemas, almacenamiento) sean accesibles y utilizables por los usuarios (o procesos) autorizados cuando estos lo requieran.***

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

Muchas veces se utilizan indistintamente los conceptos Seguridad de la Información con el de Seguridad Informática. Sin embargo, vale aclarar sus diferencias

La **ciberseguridad** se encarga de la protección de los sistemas informáticos, entendiéndose esto como la conjunción de la información almacenada en medios magnéticos, las aplicaciones (software), los equipos que soportan la información (hardware) y las personas que hacen uso de la misma (usuarios). En este enfoque se utiliza el aspecto técnico de la seguridad, se realizan análisis de riesgos basados en los activos involucrados en los sistemas informáticos, vulnerabilidades de los mismos y amenazas a las que se ven expuestos y se implementan medidas de seguridad (salvaguardas) para mantener los riesgos en un nivel aceptable.

La **seguridad de la información** es un proceso que amplía la visión técnica de la seguridad informática extendiéndose a considerar todas las personas, los procesos, funciones y activos de toda la organización. En este enfoque se consideran los riesgos organizacionales, operacionales y físicos y se hace hincapié en el factor humano ya que la implementación de medidas de seguridad requiere modificación de comportamientos y actitudes que generalmente son rechazados por la resistencia al cambio. Las organizaciones deben establecer políticas de seguridad de la información (Ver Apuntes complementarios capítulo 1: Políticas de Seguridad de la Información de la UTN) que guiarán luego el proceso de Gestión de Riesgos que veremos en esta unidad.



Tomando como base el concepto amplio de Seguridad de la Información existen numerosos estándares, guías de buenas prácticas y marcos de trabajo (que consideraremos documentos de referencia) dedicados a diferentes aspectos de la seguridad de la información.

Nos interesan de estas buenas prácticas en cuanto a la Gestión de Riesgos, parte integrante del Plan Estratégico de Tecnologías de Información;

1. Las dedicadas a establecer metodologías referidas al proceso en sí y a la identificación de riesgos y su tratamiento
2. Las dedicadas a establecer mecanismos para actuar ante la materialización de un riesgo: contingencia, recuperación y continuidad de las operaciones del negocio.

Entre ellas podemos mencionar:

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

COBIT 2019

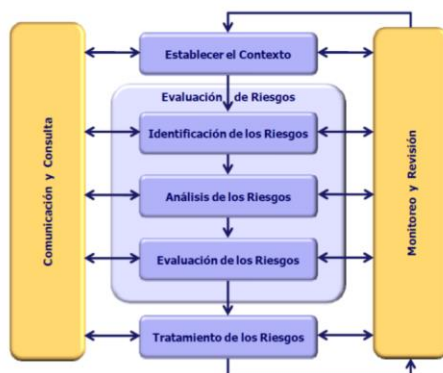
Como ya hemos analizado, COBIT 2019 separa los objetivos de Gobierno de los de Gestión de TI. Para cada objetivo el marco de trabajo establece Procesos que incluyen prácticas requeridas y actividades a realizar.

Dentro de los objetivos de Gestión y en el dominio: **Alinear, Planificar y Organizar** (APO), se encuentra el Objetivo: **Gestionar el Riesgo**, para el cual establece el siguiente un proceso en el cual se identifican siguientes prácticas¹:

- **Recopilar datos:** Integrar la gestión del riesgo empresarial relacionado con la TI con la gestión del riesgo empresarial global, y equilibrar los costos y beneficios de la gestión del riesgo empresarial relacionado con las TI.
- **Analizar el riesgo.** Desarrollar una visión fundamentada del riesgo de TI vigente, que soporte las decisiones de riesgo.
- **Mantener un perfil de riesgo.** Mantener un inventario de los riesgos conocidos y los atributos de riesgo, incluidos la frecuencia esperada, impacto potencial y respuestas. Documentar los recursos, capacidades y actividades de control actuales relacionados con elementos de riesgo.
- **Articular el riesgo.** Comunicar de manera oportuna información sobre el estado actual de las exposiciones y oportunidades relacionadas con TI a todas las partes interesadas requeridas para obtener una respuesta apropiada
- **Definir un portafolio con acciones de gestión de riesgos.** Gestionar las oportunidades para reducir el riesgo a un nivel aceptable como un portafolio.
- **Responder al riesgo.** Responder de manera oportuna a eventos de riesgo materializados con medidas eficaces para limitar la magnitud de las pérdidas.

ISO 31000: 2018: GESTIÓN DEL RIESGO. DIRECTRICES

COBIT 2019 está alineado a ISO 31000:2018 que establece los principios y guías genéricas para la Gestión de los Riesgos. El proceso se muestra en la siguiente figura:



¹ El Proceso completo de COBIT 2019 para Gestionar el Riesgo se encuentra en el Anexo I de este documento

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****MAGERIT V.3².**

Es un método formal para investigar los riesgos que soportan los Sistemas de Información y para recomendar las medidas apropiadas que deberían adoptarse para controlar estos riesgos. El método está contenido en tres libros. En el Libro I se establece el proceso de Gestión de Riesgos basado en la norma ISO 31000 y el método para el análisis de riesgos basado en la identificación de activos.

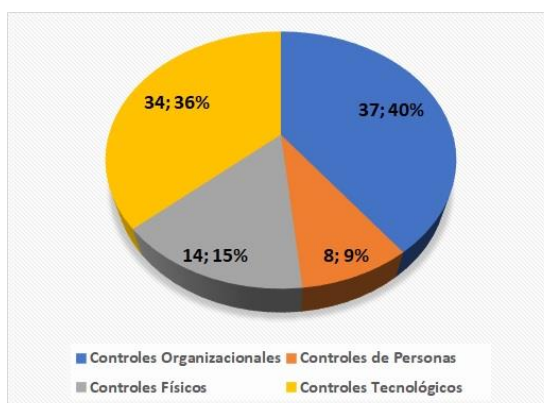
**SERIE ISO 27000³**

Dentro de la serie, la ISO27001:2022 es certificable y las restantes son guías de buenas prácticas. Algunos de los documentos principales de la norma son:

- ISO 27001:2022 (norma certificable) Es aplicable a todos los tipos y tamaños de organización (por ejemplo, empresas comerciales, agencias gubernamentales, organizaciones sin fines de lucro). Propone un marco para el Sistema de Gestión de la Seguridad de la Información (SGSI) que permita coordinar la definición de políticas, objetivos y alcance de la seguridad de la información en la organización, el análisis, valorización y tratamiento de los riesgos sobre los activos involucrados, los controles a realizar y su monitorización para luego realizar las mejoras correspondientes.
- ISO 27002:2022 "*Seguridad de la información, ciberseguridad y protección de la privacidad – Controles de seguridad de la información*" actualiza la versión anterior del 2013 quedando una estructura ordenada en temas que agrupa controles. Los cuatro temas diferenciados por la norma se muestran en la siguiente figura:

² MAGERIT V.3 Metodología Automatizada de Análisis y Gestión de Riesgos de los Sistemas de Información de las Administraciones Públicas de España.
https://administracionelectronica.gob.es/pae/Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html#.Wwv37EgqvuuE

³ La visión general de las normas que componen la serie ISO27000 puede leerse de:
<https://www.iso.org/home.html> .

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

A cada uno de los 93 controles se le asocian atributos con valores posibles.

- **Tipo de Control:** Preventivo, Detectivo o Correctivo.
 - **Propiedades de Seguridad de la información:** Confidencialidad, Integridad y Disponibilidad.
 - **Conceptos de Ciberseguridad:** identifica las 5 funciones NIST² del marco de ciberseguridad dentro de la organización: Identificar, Proteger, Detectar, Responder, Recuperar.
 - **Capacidades operacionales:** se utilizan para clasificar controles desde una perspectiva práctica que permite asignar responsabilidades y establecer lineamientos de implementación.
 - **Dominios de seguridad:** Utilizados para clasificar los controles desde la perspectiva de los dominios de la seguridad de la información, experiencia, servicios y productos: Gobernanza y ecosistema, Protección, Defensa y Resiliencia, haciendo referencia a un conjunto de bienes y recursos sujetos a una política de seguridad común.
- ISO 27005:2022: “*Seguridad de la información, ciberseguridad y protección de la privacidad: directrices para la gestión de riesgos de seguridad de la información*” contiene diferentes recomendaciones y directrices generales para la establecer el proceso de Gestión de Riesgos.

Las normas ISO 27000 no establecen metodologías específicas por lo que pueden ser complementados con otros marcos de trabajo que iremos mencionando a lo largo de esta Unidad

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

EL PROCESO DE GESTIÓN DE RIESGOS

A partir de las buenas prácticas mencionadas anteriormente podemos establecer que la **Gestión de Riesgos** es un proceso iterativo basado en el conocimiento, evaluación y manejo de los riesgos, con el propósito de mejorar la toma de decisiones organizacionales y aplicable a cualquier situación donde un resultado no deseado o inesperado pueda ser significativo o donde se identifiquen oportunidades.

Para atender a las contingencias que puedan presentarse en cuanto a la seguridad de la información, es imprescindible conocer los riesgos a los que nos enfrentamos para poder gestionarlos.

Las Organizaciones interactúan en un ambiente donde clientes, regulaciones gubernamentales, competencia y tecnología cambian constantemente, hecho éste que las obliga a estar preparadas para adaptarse a estos cambios. La siguiente figura muestra los conceptos referidos a riesgos y sus relaciones:



Conceptos asociados a la Gestión de Riesgos

Los conceptos que se muestran en la figura estarán mencionados en referencia al Proceso de Gestión de Riesgos de COBIT 2019, del que analizaremos las prácticas más relevantes a nuestro objeto de estudio:

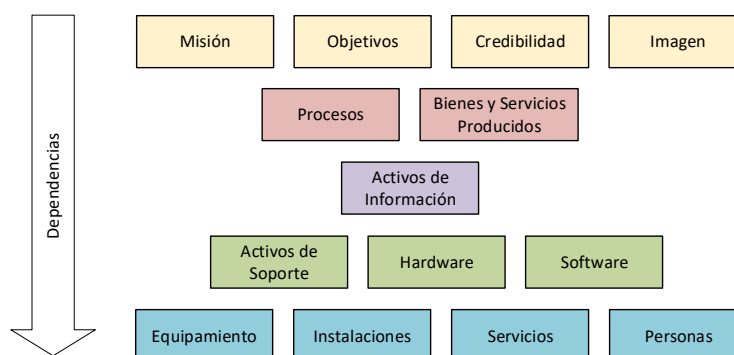
ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****RECOPILAR DATOS**

Se deberán determinar los riesgos inherentes y documentar sus características para lo cual utilizaremos el método basado en la identificación de activos propuesto por Magerit V3.

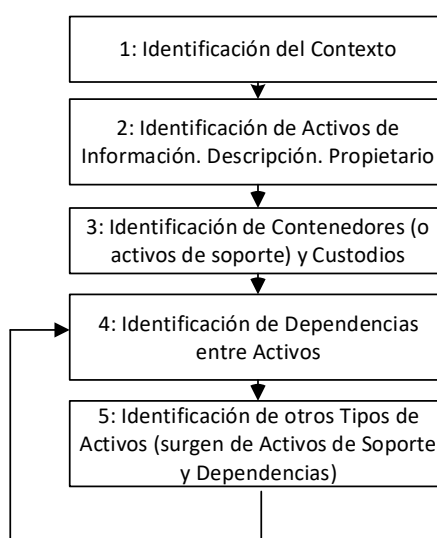
IDENTIFICACIÓN DE ACTIVOS

Los activos son los recursos necesarios para que una organización o proceso de ésta funcione correctamente y alcance sus objetivos. Realizar un inventario de activos permite la identificación de activos y componentes críticos y es esencial para conocer qué debe protegerse. La tipificación de los activos es tanto una información documental de interés como un criterio para la posterior identificación de **amenazas** potenciales y **vulnerabilidades**, y permitirán establecer **controles** apropiados a la naturaleza del activo.

Referido al inventario de activos, y en función de la clasificación realizada en la Unidad 1, se puede considerar el siguiente cuadro de dependencias entre activos:



Un procedimiento que puede seguirse para la identificación de activos es el siguiente:



Partiendo del análisis del contexto, para el que se debe contar con empleados expertos para la especificación de objetivos de la organización, procesos de negocio y actividades, se pueden identificar los activos de información que se procesan, consumen o producen en el transcurso de

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

estas actividades. Se puede recurrir a documentación existente, de lo contrario se deberá realizar un esfuerzo adecuado al objetivo de identificación de activos de información, es decir, ni una identificación de actividades de bajo nivel (excesivamente detallada) ni de muy alto nivel.

Un inventario de activos podrá contener:

- **Identificador** del Activo de Información: Puede servir para registrar el activo y hacer referencias
- **Nombre:** El nombre del activo como se conoce para la organización
- **Descripción:** Describe las características del Activo. Puede indicarse si es un documento legal o requerido por el propio proceso
- **Propietario o Dueño del Activo:** son aquellos individuos que tienen la responsabilidad principal de la viabilidad y la capacidad de supervivencia del activo.
- **Contenedores o Soportes del Activo de Información:** Este concepto ayuda a diferenciar el activo de información propiamente dicho de la forma en que se almacena, procesa y distribuye.
- **Custodio del Activo:** refiere a cualquier persona en la organización que tenga la responsabilidad de proteger un activo de información a medida que se almacena, transporta o procesa. Está vinculado al activo de soporte y a su contenedor.
- **Origen:** ayuda a identificar quién es el que tiene la potestad de generar el Activo de Información. Se deberá identificar si se requiere la identificación de la entidad de origen del Activo.
- **Acceso:** Dependiendo del acceso que podrá realizarse al Activo de información se podrá realizar una subclasificación, por ejemplo:
 - ✓ **Público:** sin requisitos de confidencialidad. Cualquier persona de la organización o terceros puede tener acceso a la información.
 - ✓ **Compartido:** activos compartidos entre grupos o personas no pertenecientes a la organización
 - ✓ **Reservado:** restringido el acceso a los empleados de la organización.
 - ✓ **Confidencial:** acceso restringido a una lista específica de personas. En estos casos será conveniente identificar si la información contiene datos personales o sensibles
- **Dependencias:** se incluirán aquí la denominación de todos los activos a partir de los cuales la materialización de una amenaza tenga como consecuencia efectos en la seguridad del activo de información identificado. a partir de las dependencias identificadas en los activos de información se realizarán los inventarios de activos correspondientes clasificados según convenga a la organización

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****IDENTIFICACIÓN DE AMENAZAS Y VULNERABILIDADES**

Habiendo identificado los activos será necesario identificar las **amenazas** que pueden actuar sobre dichos activos. La identificación de amenazas permite además el análisis de las **vulnerabilidades** que pueden ser aprovechadas por dichas amenazas. El atacante puede contar con recursos o no para materializar el ataque. (En el Anexo II puede analizarse las herramientas que utiliza un atacante en un ciberataque.)

Al igual que en el procedimiento de identificación de activos, la tarea de identificación de amenazas y vulnerabilidades debe significar un esfuerzo adecuado.

Basado en la identificación de activos, las taxonomías que utilizaremos hacen mención a:

- Amenazas (MAGERIT)
- Comunidades de amenazas (FAIR⁴).

Todos ellos intentan establecer subconjuntos de la población total de amenazas que comparten características claves y proponen metodologías para la identificación y clasificación de las mismas.

Examinar la naturaleza de una organización (por ejemplo, la industria en la que se encuentra) y las condiciones que rodean al activo (por ejemplo, su valor, el personal que accede a su uso, su contenedor o las instalaciones donde se encuentra), puede ser un inicio para la identificación y clasificación.

MAGERIT establece una clasificación según el origen de la amenaza, a partir de ella distingue los activos que pueden ser objeto de dicha amenaza y a qué dimensión de éstos afecta (confidencialidad, integridad y disponibilidad). La clasificación incluye las siguientes amenazas generales: Desastres naturales (de origen accidental), de origen industrial (del entorno accidentales o de origen humano accidentales o deliberados), errores y fallos no intencionados (de origen humano), ataques intencionados. Además, establece una correlación para identificar amenazas que pueden provenir de errores o ataques deliberados, las que solo pueden provenir de errores y las que solo pueden provenir de ataques deliberados. (Ver MAGERIT libro II. Catálogo de elementos)

FAIR hace una descripción de las comunidades de amenazas y características comunes que pueden servir para luego para establecer la probabilidad de que las amenazas se materialicen:

FAIR distingue entre comunidades de amenazas:

- ✓ Internas: Empleados, contratistas y vendedores, socios
- ✓ Externas: Ciberdelincuentes (hackers profesionales), espías de la competencia, Hackers no profesionales

Características de estas comunidades:

⁴ Factor Analysis Information Risk (FAIR)

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

- ✓ Motivación: ideología del atacante, ganancia financiera, venganza
- ✓ Intento primario: solo conseguir acceso, dañar o destruir
- ✓ Patrocinio: posibilidad de que exista beneficio (patrocinado o no) para del atacante
- ✓ Características preferidas del objetivo general: entidades o personas que representan una ideología en particular
- ✓ Objetivos preferidos: personas, infraestructura (edificios, comunicaciones, energía, etc.)
- ✓ Características preferidas del objetivo específico: alto perfil, alta visibilidad
- ✓ Capacidades del atacante: varían según el vector de ataque o ruta que sigue el atacante para materializar la amenaza
- ✓ Tolerancia al riesgo: consecuencias negativas que el agente de amenaza es capaz de tolerar.

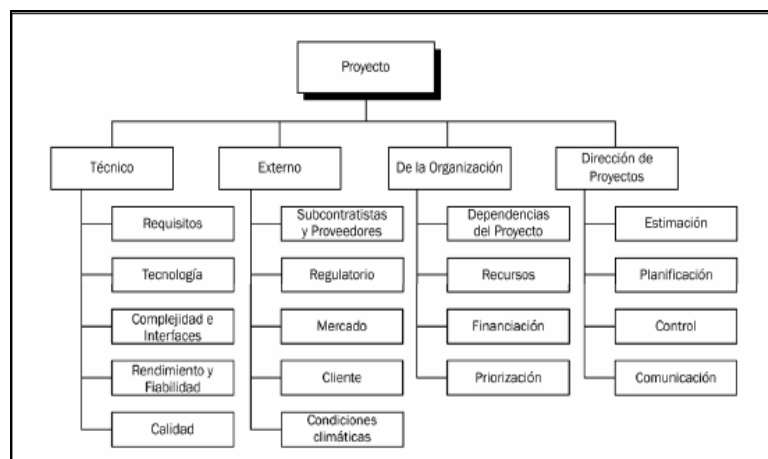
TAXONOMÍAS PARA LA IDENTIFICACIÓN DE RIESGOS

Dependiendo de los diferentes contextos en Tecnologías de la Información se han desarrollado listas de clasificación de riesgos (taxonomías) que permiten que el equipo encargado de identificar riesgos pueda pensar con mayor amplitud sobre los mismos porque ya dispone de una lista de áreas o activos susceptibles de esconder riesgos procedentes de diferentes situaciones. En ocasiones se utiliza una lista de chequeo basada en una taxonomía con preguntas orientadas a grupos de riesgos ya que trabajar con listas muy extensas puede resultar complejo. También pueden emplearse para unificar la terminología que el equipo puede utilizar para supervisar y notificar el estado de los riesgos a lo largo de un proyecto o en los momentos del control.

Existen taxonomías que describen las fuentes de riesgo de proyectos de desarrollo de software entre las que se incluyen las realizadas por Barry Boehm, Caper Jones y la desarrollada por el SEI denominada Software Development Risk Taxonomy. También existen taxonomías relacionadas con Proyectos de Adquisiciones de Software⁵.

Presentaremos algunas clasificaciones para la a la identificación de riesgos en Proyectos o Áreas de Sistemas y Tecnologías de Información.

El **PMI** propone la siguiente estructura de desglose de riesgos que pueden darse en Proyectos:



⁵ En la carpeta de apuntes complementarios pueden encontrarse los documentos específicos de las taxonomías mencionadas.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

El **SEI** propone una clasificación para riesgos de la operación de tecnologías de información denominada **Taxonomy of Operational Cyber Security Risks**⁶. La clasificación identifica y organiza la fuente de estos riesgos en cuatro clases:

1. **Acciones (o inacción) de las personas:** realizadas tanto deliberada como accidentalmente
2. **Fallas de los sistemas y tecnología:** fallas del hardware, software y sistemas de información
3. **Fallas de los procesos internos:** problemas en los procesos internos del negocio que impactan en la habilidad para implementar, gestionar y sostener a la seguridad.
4. **Eventos externos:** cuestiones fuera del control de la organización.

Cada clase se descompone en subclases que se describen por los elementos que la componen:

1. Acciones de las Personas	2. Fallas de los sistemas y tecnologías	3. Fallas de Procesos Internos	4. Eventos externos
1.1 Involuntarias	2.1 Hardware	3.1. Diseño de Procesos y Ejecución	4.1 Desastres
1.1.1 Equivocación (acción incorrecta)	2.1.1 Capacidad	3.1.1 Flujo de Procesos	4.1.1 Climatológicos
1.1.2 Error (por desconocimiento)	2.1.2 Rendimiento	3.1.2 Documentación de Procesos	4.1.2 Incendios
1.1.3 Omisión (por apresuramiento)	2.1.3 Mantenimiento	3.1.3 Roles y responsabilidades	4.1.3 Inundaciones
1.2 Deliberadas	2.1.4 Obsolescencia	3.1.4 Notificaciones y alertas	4.1.4 Terremotos
1.2.1 Fraude	2.2 Software	3.1.5 Flujo de Información	4.1.5 Disturbios
1.2.2 Sabotaje	2.2.1 Compatibilidad	3.1.6 Escalado de problemas	4.1.6 Pandemias
1.2.3 Robo	2.2.2 Administración de Configuraciones	3.1.7 Acuerdo de Nivel de Servicio	4.2 Cuestiones Legales
1.2.4 Vandalismo	2.2.3 Control de Cambios	3.1.8 Actividad fuera de control	4.2.1 Regulaciones
1.3 Inacción	2.2.4 Parámetros de Seguridad	3.2 Control de Procesos	4.2.2 Legislación
1.3.1 Habilidad	2.2.5 Prácticas de Codificación	3.2.1 Monitorización del estado	4.2.3 Litigios
1.3.2 Conocimiento	2.2.6 Testing	3.2.2 Métricas	4.3 Cuestiones del Negocio
1.3.3 Guía	2.3 Sistemas	3.2.3 Revisiones Periódicas	4.3.1 Fallas del Suministro
1.3.4 Disponibilidad	2.3.1 Diseño	3.2.4 Propietario o prácticas de gobierno del proceso	4.3.2 Condiciones del Mercado
	2.3.2 Especificaciones	3.3 Procesos de Soporte	4.3.3 Condiciones Económicas
	2.3.3 Integración	3.3.1 Dotación del Personal	4.4 Dependencias con Servicios
	2.3.4 Complejidad	3.3.2 Recursos económicos	4.4.1 Servicios Públicos / No Públicos
		3.3.3 Entrenamiento y desarrollo	4.4.2 Servicios de Emergencia
		3.3.4 Otros recursos necesarios de soporte a los procesos	4.4.3 Combustible 4.4.4 Transporte

⁶ Ver Documento Anexo 3: Descripción de la Taxonomía SEI

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

ANALIZAR EL RIESGO

Si bien el riesgo ha sido considerado generalmente con consecuencias negativas, algunos de los documentos de referencia consideran al mismo también con consecuencias positivas.

Por ejemplo, **ISO 31000** define **riesgo** como el *efecto de la incertidumbre sobre el logro de los objetivos*, donde *efecto* es un desvío respecto a lo esperado (ya sea positivo o negativo).

En sintonía con la definición de ISO 31000, COBIT 2019 y PMI⁷ utilizan el concepto dual de riesgo (resultados positivos y negativos). En el contexto de Proyectos **PMI** define al riesgo relacionado con las **Oportunidades** (resultados positivos) y las **Amenazas** (resultados negativos). Los objetivos de la Gestión de los Riesgos del Proyecto son aumentar la probabilidad y el impacto de los eventos positivos, y disminuir la probabilidad y el impacto de los eventos adversos para el proyecto.

Además, y en función de un efectivo proceso de Gestión de Riesgos, deberemos establecer definiciones que permiten evaluar **niveles de riesgo**.

VALORACIÓN DE LOS RIESGOS

Los **riesgos** se pueden evaluar en términos de la combinación de las consecuencias de un evento o incidente (**efecto** de amenazas/oportunidades explotando las vulnerabilidades/fortalezas de los activos) al que denominaremos **IMPACTO** y la incertidumbre o **PROBABILIDAD** de que ese evento o incidente se produzca o no, ya que el riesgo es algo que todavía no ha ocurrido.

Los procesos de evaluación de riesgos incluyen técnicas para determinar la importancia de un riesgo, basado tanto en la probabilidad como en su impacto.

El estado del riesgo, exposición o severidad se calcula como:

$$\text{SEVERIDAD DEL RIESGO} = \text{PROBABILIDAD} \times \text{IMPACTO}.$$

La severidad del riesgo puede evaluarse de dos formas:

- **Evaluación Cualitativa:** La severidad de los riesgos se calcula utilizando escalas de probabilidad e impacto
- **Evaluación Cuantitativa:** La severidad de un riesgo se calcula numéricamente

La evaluación cualitativa permitirá priorizar aquellos riesgos más severos para analizar las posibles acciones posteriores. Si bien luego será necesaria una evaluación cualitativa para comparar si el costo de las acciones que determinemos para el tratamiento de los riesgos no excede a los beneficios.

A los efectos de nuestro estudio utilizaremos la **evaluación cualitativa** para la cual estableceremos escalas:

- Impacto: 0-Insignificante 1-Menor, 2-Bajo, 3-Significativo, 4-Mayor, 5-Severo

⁷ PMI: Project Management Institute

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

- Probabilidad: 0-Imposible, 1-Raro (< 3%), 2- Poco Probable (<10%), 3- Moderado (<30%), 4-Probable (<60%), 5-Casi seguro (>60%)

En función a estas escalas se puede establecer una matriz para medir la severidad del riesgo en función de las amenazas (en este caso negativo pero de la misma forma si fuese positivo en función de las oportunidades):

		Impacto <i>¿Qué tan severos serían los resultados si ocurriera el riesgo?</i>				
		Insignificante 1	Menor 2	Significativo 3	Mayor 4	Severo 5
Probabilidad <i>¿Cuál es la probabilidad de que ocurra el riesgo?</i>	5 Casi seguro	Medio 5	Alto 10	Muy alto 15	Extremo 20	Extremo 25
	4 Probable	Medio 4	Medio 8	Alto 12	Muy alto 16	Extremo 20
	3 Moderado	Bajo 3	Medio 6	Medio 9	Alto 12	Muy alto 15
	2 Poco probable	Muy bajo 2	Bajo 4	Medio 6	Medio 8	Alto 10
	1 Raro	Muy bajo 1	Muy bajo 2	Bajo 3	Medio 4	Medio 5

Ahora bien, para establecer qué valor de la escala corresponde al impacto podemos referirnos al **valor** que el activo tiene para la organización o a la **magnitud de la pérdida** que sufriría la misma si fuese afectado dicho activo.

Las características o atributos que hacen valioso un activo se denominan **dimensiones de valoración**. Una dimensión es una faceta o aspecto de un activo que se podrá utilizar para valorar las consecuencias o **impacto** de la materialización de una amenaza.

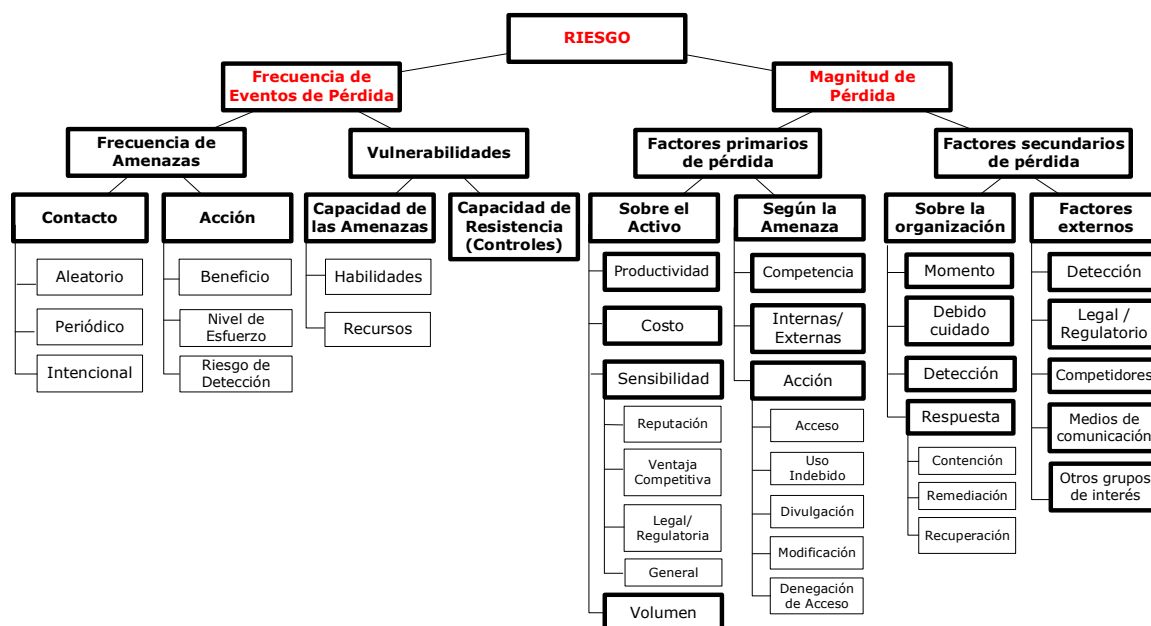
La valoración que recibe un activo en una cierta dimensión es la medida del perjuicio para la organización (sobre sus objetivos, productividad, etc.) si el activo se ve dañado en dicha dimensión

Las dimensiones de valoración que permiten establecer el nivel de criticidad de un activo son:

- **Confidencialidad:** asociado a la información y derivado del marco regulador externo o criterios internos. Los activos reciben una alta valoración desde este punto de vista cuando su revelación causaría graves daños a la organización.
- **Disponibilidad:** en función del número de personas afectadas por la falta de disponibilidad o por un funcionamiento irregular.
- **Integridad:** cuando su alteración, voluntaria o intencionada, causaría graves daños a la organización.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

La Taxonomía FAIR puede ayudar a evaluar la probabilidad (frecuencia de eventos de pérdida) y el impacto (magnitud de la pérdida) de un riesgo:

**Taxonomía FAIR (Factor Analysis for Information Risk) ⁸**

La valorización del riesgo realizada nos permitirá establecer el **riesgo inherente** (comúnmente mencionado solo como riesgo). Este es el riesgo que se presenta sin aplicar ninguna medida sobre las amenazas (u oportunidades), vulnerabilidades, impacto o probabilidad, es decir sin aplicar ninguna estrategia para disminuir (o aumentar) su severidad.

PRIORIZACIÓN PARA EL TRATAMIENTO DE LOS RIESGOS

Podemos realizar la siguiente lista de los **riesgos inherentes** identificados:

Id	Especificación del Riesgo	Categoría	Valor Escala de Probabilidad	Valor Escala de Impacto	Severidad
					Σ Severidad

Una vez obtenida la lista, la ordenamos en forma decreciente por Severidad para establecer cuáles son los riesgos para los cuales deberemos dar prioridad para su tratamiento.

Dependiendo del análisis, es probable que puedan identificarse una gran cantidad de riesgos y, por lo tanto, la Gestión de Riesgos puede convertirse en un proyecto en sí mismo. Por este motivo, adaptamos la regla de Pareto 80-20 a la Gestión de Riesgos. La experiencia dice que la suma de la severidad de los riesgos que pertenecen al 80 por ciento de la severidad total nos permitirá establecer el 20 por ciento de los riesgos a los que deberá dar prioridad para su tratamiento.

⁸ Ver Documento Anexo 4: Taxonomía FAIR. Descripción.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

Una vez establecidas las estrategias de tratamiento será necesario volver a calcular su severidad ya que tanto su probabilidad como su impacto podrán haber variado. Este valor será el **riesgo residual**, que será el riesgo que estaremos dispuestos a aceptar.

Importante: La especificación del riesgo no ha variado, solo el valor de su severidad.

El análisis de riesgos no es algo estático que se realiza por única vez. Debe ser una actividad continua ya que tanto los activos, como sus vulnerabilidades y las amenazas van cambiando con el tiempo.

RESPONDER A LOS RIESGOS

Las actividades a desarrollar para responder a los riesgos incluyen controles de tipo preventivo, detectivo y correctivo.

- **Controles Preventivos:** reducen la probabilidad o impacto del riesgo o eliminan sus causas. Se establecen para ellos estrategias de tratamiento en función de las características del riesgo
- **Controles Detectivos:** detectan el riesgo una vez ocurrido, reducen el impacto del riesgo. Se establecen para ello planes de contingencia y continuidad de negocio en función de haber definido estrategias de tratamiento.
- **Controles Correctivos:** identifican y corrigen las causas del riesgo ocurrido. Se establecen para ello planes de recuperación, que también estarán en relación a las estrategias de tratamiento.

ESTRATEGIAS DE TRATAMIENTO DE LOS RIESGOS

Las estrategias de tratamiento de los riesgos están relacionada a los controles y acciones que deberemos establecer frente a la posible materialización del riesgo de forma tal que la severidad del riesgo se vea disminuida. En relación a la ISO 27002: 2022 los controles a establecer serán del tipo *Preventivo*, relacionados con todas las propiedades de la seguridad de la información, y con el concepto de ciberseguridad *Proteger*. Las capacidades operacionales asociadas a los controles nos permitirán asignar las responsabilidades y establecer los lineamientos de implementación de las acciones requeridas para el Control.

Las estrategias que pueden aplicarse serán:

- **Estrategias de tratamiento de riesgos negativos (amenazas)**
 - **Evitar:** No se acepta de esa forma.
 - **Transferir:** a un tercero el riesgo y la gestión del mismo (Subcontratar, Asegurar)
 - **Mitigar:** Se hará lo posible para minimizar su ocurrencia (probabilidad) y consecuencias (impacto)
 - **Aceptar:** Se acepta las consecuencias de la posible ocurrencia del riesgo

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

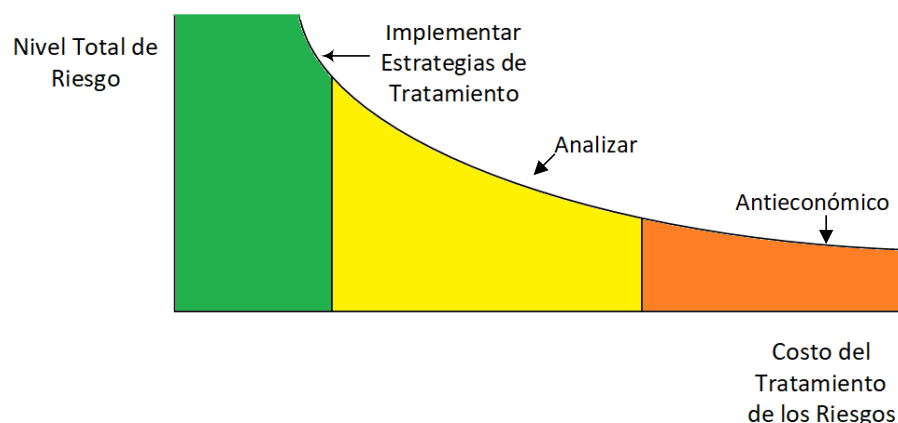
Unidad 2: Administración de Recursos en Áreas de Sistemas de Información



○ **Estrategias de tratamiento de riesgos positivos (oportunidades)**

- **Explotar:** Se hará lo posible para asegurarse que la oportunidad sea una realidad
- **Compartir:** Transferir a un tercero mejor capacitado para capturar la oportunidad
- **Mejorar:** Se hará lo posible por maximizar su ocurrencia (probabilidad) y consecuencias (impacto)
- **Aceptar:** Estoy dispuesto a aceptar las consecuencias de su posible ocurrencia

Deberemos balancear el costo de implementación de los controles y acciones de tratamiento de los riesgos contra los beneficios derivados en función del nivel de riesgo:



Los imprevistos y todas las cuestiones relacionadas a la respuesta a riesgos deben gestionarse a través de **reservas**, que pueden ser:

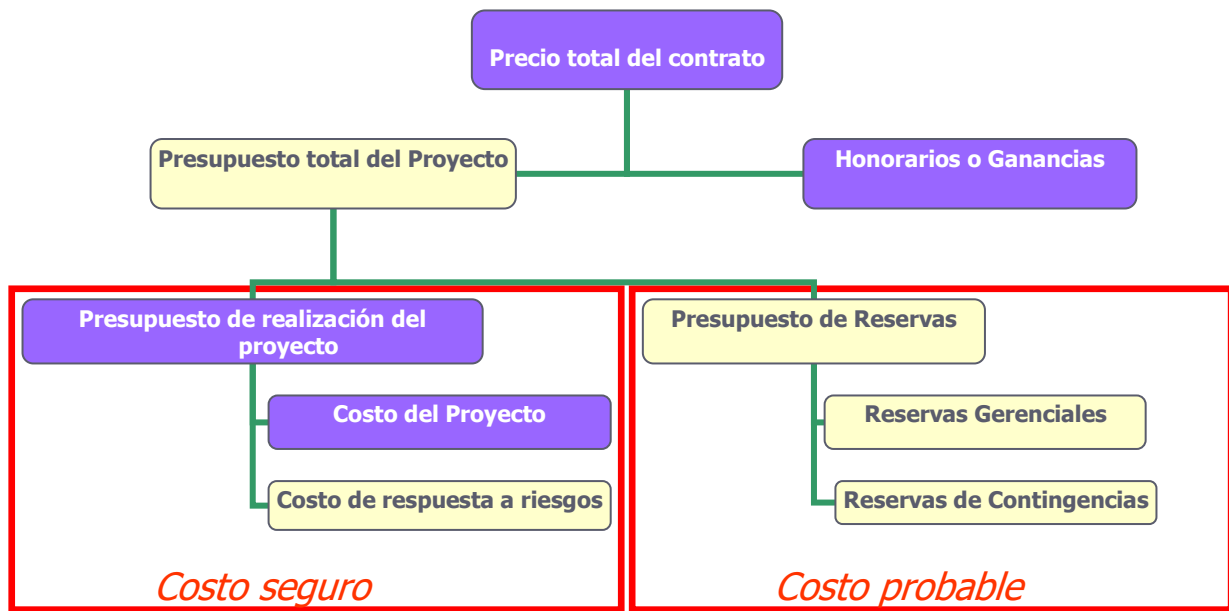
Gerenciales: Atiende a los imprevistos

De Contingencia: Atiende a todas las cuestiones relacionadas a la planificación de la respuesta a riesgos.

El cuadro siguiente muestra cómo pueden afectar al precio de un contrato de un Proyecto y pueden ser asimiladas a cualquier proceso o actividad de la organización

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información



ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

PLANES DE CONTINGENCIA, RECUPERACIÓN Y CONTINUIDAD DE NEGOCIO

Identificados los riesgos y realizado su tratamiento quedará actuar sobre el riesgo residual o remanente. Este es el nivel de riesgo que la organización está dispuesta a aceptar y para el que deberán plantearse los planes de contingencia, recuperación y continuidad de negocio.

Un **plan de contingencia** especifica los procedimientos que se ejecutarán ante la eventual ocurrencia de un riesgo.

Al plan de contingencia sigue inmediatamente el **Plan de Recuperación** que permitirá restablecer rápidamente los servicios de la organización.

Estos planes deben prever:

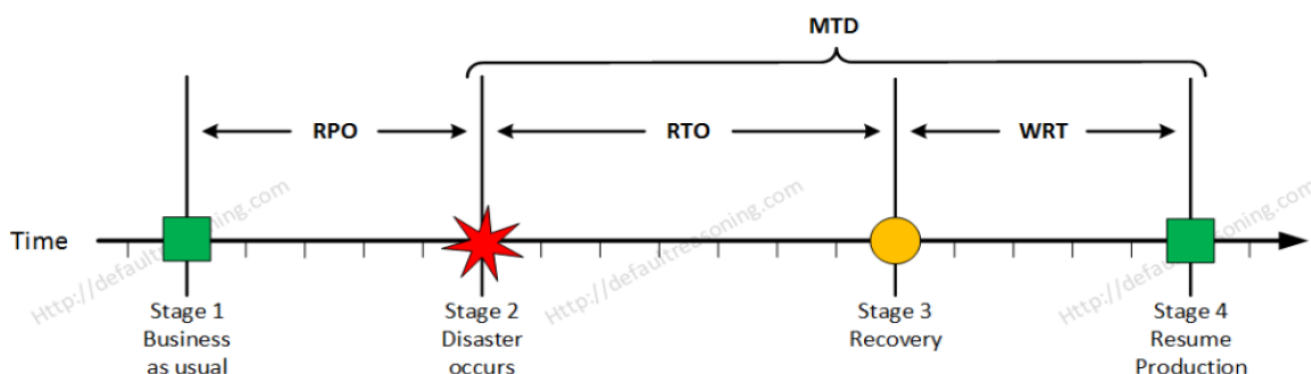
- Actividades de monitoreo de la materialización de un riesgo en función de las alarmas o indicadores establecidos en la identificación del riesgo.
- Definición de las acciones a poner en práctica una vez materializado el riesgo:
- Formación del equipo involucrado en la ejecución de los planes de contingencia y recuperación.
- Entrenamiento mediante simulacros o pruebas

A partir de la detección de la materialización del riesgo los planes deberán indicar la forma de:

- Evaluar los daños
- Priorizar las actividades del plan de acción
- Ejecutar las actividades
- Evaluar los resultados
- Restablecer las operaciones

En el tiempo que media entre que sucede la contingencia y se recuperan los servicios se deberán mantener operativos los procesos críticos de la organización, a esto se denomina Plan de Continuidad de Negocio. El plan de continuidad de negocio especificará cómo se realizarán las actividades críticas del negocio para las cuales puede no contarse con los activos normalmente utilizados en las mismas.

Para comprender cómo operan estos planes encadenados analicemos el siguiente gráfico



ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

1. Supongamos que tenemos un backup del sistema completo realizado en este punto
2. Ocurre un desastre

RPO (Recovery Point Objective): determina el objetivo de posible pérdida máxima de datos introducidos desde el último backup, hasta la caída del sistema

RTO (Recovery Time Objective): determina el tiempo en que se puede recuperar el sistema.

3. Recuperación: que no es completa ya que habremos perdido todo lo ocurrido entre el punto 1 y 2 (RPO)

WRT (Work Recovery time): El tiempo máximo necesario para verificar el sistema, la integridad de los datos, entre otros. Por ejemplo: chequear información faltante, chequear bases de datos, logs, levantar servicios, etc.

Entre las Buenas Prácticas que refieren a la implementación de estos planes se pueden mencionar:

- **NIST-800-34:** Planes de Contingencia y recuperación. Proporciona una metodología para medir el desarrollo de planes de contingencia, considerados únicos para cada sistema, brindando medidas preventivas, estrategias de recuperación y consideraciones técnicas apropiadas para la confidencialidad, integridad y disponibilidad de la información del sistema, requisitos y el nivel de impacto del sistema.
- **Normas ISO 22301 y BS 25999-** Gestión de la Continuidad del Negocio (Business Continuity Management -BCM-): Se enfocan en considerar la disponibilidad como dimensión crítica de la seguridad de la información, por lo que el análisis de riesgos se realiza en función de considerar el impacto en el negocio de incidentes o eventos que provoquen una interrupción o degradación de las operaciones.

GESTIÓN DE SERVICIOS EN TECNOLOGÍAS DE INFORMACIÓN

INTRODUCCIÓN

Como hemos analizado en la Unidad 1, en la actualidad se requiere de la separación de responsabilidades en cuanto al Gobierno y la Gestión de TI.

Esto es una resultante del desarrollo que las tecnologías de información y comunicaciones han tenido en las últimas décadas y el impacto de las mismas en los procesos de negocio.

La separación de estas responsabilidades debe tender a flexibilizar la estructura de las áreas de TI sin desatender a los procesos de soporte requeridos por la organización.

Las normas, modelos, marcos y metodologías relacionados con TI, de los cuales varios han sido mencionados anteriormente, permiten atender a retos como la calidad del producto, los procesos de desarrollo de software, su mantenimiento, la adquisición de tecnologías, la seguridad de los sistemas de información, la profesionalización de TI, entre otros.

Como hemos podido analizar, estos modelos han ido evolucionando atendiendo al cambio de paradigma, del modelo tradicional donde se focaliza en la tecnología, se tiene una actitud reactiva ante la ocurrencia de problemas, los procesos son informales y se orientan al producto, por un paradigma orientado al negocio, donde se focaliza en los procesos, se adquiere una actitud proactiva y los procesos se implementan a partir de buenas prácticas.

Para completar este enfoque se debe también tener en cuenta la necesidad de mejorar la gestión y entrega de servicios TI (GTSI o ITSM: IT Service Management) que tendrá un impacto directo sobre la calidad del servicio ofrecido. Entre los marcos de trabajo existentes dentro de esta disciplina pueden nombrarse ITIL (Information Technology Infrastructure Library), eSCM (enabled Service Capability Model), COBIT 2019 (con los dominios de objetivos mencionados en la Unidad 1) y entre las normas certificables se encuentra la ISO 20000.

Hemos seleccionado ITIL 4 para comprender las prácticas esenciales requeridas para la Gestión de servicios.

CONCEPTOS DE LA GESTIÓN DE SERVICIOS DE TI (ITSM)

Se introducen aquí ciertos conceptos que es conveniente explicar para comprender los fundamentos en que se basa la Gestión de Servicios en TI: servicio, calidad, valor, activos del servicio, administración de la relación con clientes y usuarios y gestión de servicios basada en procesos.

SERVICIO

Se debe entender como **Servicio** al conjunto de recursos provisto a los clientes para apoyarlo en la operación de una o más áreas de negocio. Un servicio es percibido como algo único y completo. La provisión de servicios de TI refiere a la administración completa de la infraestructura de TI: hardware, software, herramientas y relaciones con los clientes.

Un servicio, en el contexto de las TI, es el resultado de la interacción de un Cliente con la organización de TI proveedora y por lo tanto la calidad del mismo depende, hasta cierto punto, de la forma en que el proveedor del servicio y el cliente interactúan.

En contraste con el proceso de manufactura, cliente y proveedor pueden realizar cambios mientras el servicio se está desarrollando. Cómo el cliente percibe la calidad del servicio y cómo el proveedor piensa que lo provee, dependen de la experiencia personal y las expectativas.

La percepción del cliente es esencial en la provisión de servicios. Los clientes generalmente se realizarán las siguientes preguntas para evaluar la calidad del servicio ¿Se alineó el servicio con mis expectativas? ¿Podré esperar un servicio similar la próxima vez? ¿El costo de este servicio es razonable?

Que el servicio complete las expectativas del cliente depende de cómo se hayan acordado los niveles de servicio más que de cómo el proveedor lo haya realizado.

Se requiere un diálogo continuo del proveedor con el cliente para refinar el servicio y para asegurar que ambos conozcan qué se espera del mismo.

CALIDAD DEL SERVICIO

La **Calidad** de un servicio refiere entonces a cuánto satisfizo el servicio las expectativas del cliente. Para ser capaz de proveer calidad, el proveedor deberá evaluar continuamente cómo es percibido el servicio por el cliente y cuáles son las expectativas del cliente en el futuro. Un cliente podrá considerar normal lo que otro considera un requerimiento especial y viceversa.

Haciendo referencia a las normas ISO 8402 podemos mencionar que calidad es el "*Conjunto de propiedades y características de un producto o servicio que le confieren su aptitud para satisfacer necesidades explícitas o implícitas*"

En cuanto al *costo razonable* al que se hace referencia en la introducción puede considerarse como la satisfacción de una necesidad *implícita*. Una vez que se ha acordado qué se espera del servicio, el siguiente paso es acordar cuánto costará. En esta etapa el proveedor del servicio deberá

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

ser consciente de los costos en los que incurrirá y los actuales valores del mercado para servicios comparables. Un cliente puede no estar satisfecho con un proveedor que ocasionalmente excede las expectativas y otras lo decepcione. Proveer una calidad constante es uno de los más importantes pero dificultosos aspectos de la industria de los servicios.

Existe una vasta bibliografía referente al aseguramiento de la calidad basada en el círculo Planificar-hacer-revisar-actuar (plan-do-check-act) planteado por William Edwards Deming que será conveniente consultar en el momento de organizar las actividades de calidad.

Algunas organizaciones requieren a sus proveedores tener una **certificación** ISO-9001. Estas certificaciones prueban que el proveedor tiene un adecuado sistema de calidad cuya efectividad es evaluada frecuentemente por un auditor independiente. Un certificado ISO no proporciona la garantía absoluta de la calidad del servicio del proveedor, pero indica que el mismo considera seriamente el aseguramiento de calidad y está preparado para discutirlo.

Otras organizaciones ponen énfasis en la **madurez organizacional** del proveedor de los servicios de TI que contratan. En la industria de TI esto es conocido en el contexto del CMMi (Capability Maturity Model Integrated) del SEI (Software Engineering Institute de Carnegie Mellon University). Según el nivel de madurez obtenido en las evaluaciones se pueden esperar distintos niveles de servicio.

VALOR DEL SERVICIO

Los servicios deben ser definidos como un medio de aportar valor al cliente sin que éste deba asumir los riesgos y costos específicos de su prestación. El valor al que se refiere no depende exclusivamente del valor económico asociado al resultado específico de cada servicio. Incluye algunos otros intangibles entre los que se incluye la percepción del cliente. En esta ecuación del valor se contemplan del lado positivo la **utilidad** y la **garantía** y del lado negativo aspectos tales como la pérdida de control de todo el proceso, costos ocultos, una inferior calidad o “caer cautivo” en manos de un proveedor de servicios.

El proveedor debe tener en cuenta que el valor para el cliente está en el **resultado del servicio** y el impacto que éste tiene en su negocio y no en el servicio en sí mismo.

La utilidad y garantía de un servicio son con frecuencia interdependientes y a la hora de concebir un nuevo servicio la organización TI debe buscar un equilibrio entre ambas minimizando a su vez los aspectos que los potenciales clientes puedan percibir negativamente o como riesgos.

La utilidad requiere que el servicio cumpla los requisitos del cliente, aumente el rendimiento y resulte en un beneficio disminuyendo los costos o contribuyendo a aumentar los ingresos. La garantía presupone que el servicio estará disponible cuando se lo necesite, estará correctamente dimensionado para cumplir sus objetivos, será seguro y dispondrá de mecanismos de respaldo que permitirán su continuidad

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****ACTIVOS DEL SERVICIO**

Para que una organización TI pueda ofrecer valor en forma de servicios debe hacer buen uso de sus **recursos** y **capacidades**.

Los **recursos** son la “materia prima” necesaria para la prestación del servicio e incluyen el capital, las infraestructuras, aplicaciones e información.

Las **capacidades** representan las habilidades desarrolladas a lo largo del tiempo para transformar los recursos en valor a través de la gestión, la organización, los procesos y el conocimiento.

Y en la base de ambos se encuentra el personal que es en sí mismo un recurso que aporta entre otras capacidades su profesionalidad, creatividad y capacidad de liderazgo.

Las capacidades son por sí solas incapaces de crear valor a falta de los adecuados recursos y estos últimos no serían bien utilizados en caso de carecer de las correspondientes capacidades. Por lo tanto, la organización TI debe buscar el adecuado equilibrio entre ambos para aportar el máximo valor al cliente en forma de servicios.

**ADMINISTRACIÓN DE LA RELACIÓN CON EL CLIENTE**

La calidad de los servicios de TI depende, además, de las relaciones entre los empleados de la organización de TI y los clientes. El mayor reto será asegurar que existan buenas y efectivas relaciones entre la organización de TI y el cliente en todos los niveles, no obstante sean éstas diferentes en cada nivel.

El primer contacto que tiene un usuario con la organización de TI frente a la ocurrencia de un incidente es la Mesa de Ayuda o Centro de Servicios. La mesa de ayuda proveerá el servicio al usuario de acuerdo al nivel de servicio pactado con el cliente y éste puede no ser el nivel de servicio requerido por el usuario. Recordemos que el **usuario** en nuestro contexto es la persona frente a una PC, el empleado que utiliza los servicios de TI por sus actividades rutinarias y el **cliente** es la persona que está autorizada a realizar un acuerdo con la organización de TI referente a la provisión de servicios y responsable de asegurar que se entreguen los niveles de servicio por los que se está

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

pagando. La buena comunicación entre el cliente, el usuario y el proveedor del servicio de TI proveerá las bases de una buena relación entre las organizaciones.

GESTIÓN DE SERVICIOS BASADA EN PROCESOS

Para lograr eficiencia en la provisión de servicios de TI es necesario organizar las actividades en procesos propiciando una buena **administración de procesos**. Un **proceso** es una secuencia lógica de actividades relacionadas para obtener un objetivo determinado. Debido a esto, se deberán analizar las características y estándares de calidad de cada una de las salidas de un proceso que sirven de entradas para otro proceso de forma tal de que el resultado de la cadena de procesos sea efectivo y eficiente. Se podrá estudiar cada proceso por separado para analizar su performance estableciendo indicadores.

La **Gestión de Servicios** de TI es el marco conocido como focalizado en el proceso y en el servicio, que se denominó inicialmente Gestión de TI y que hoy conforma la disciplina ITSM (IT Service Management), enfocada en alinear los servicios de TI proporcionados con las necesidades de las empresas, poniendo énfasis en los beneficios que puede percibir el cliente final. La Gestión de Servicios de TI propone cambiar el paradigma de gestión de TI por una colección de componentes enfocados en servicios usando distintos marcos de trabajo con "buenas prácticas".

FUNDAMENTOS DE LA GESTIÓN DE SERVICIOS DE TI BASADOS EN ITIL

A fines de 1980, la calidad de los servicios de Tecnologías de la Información provistas al gobierno británico origina que la CCTA (Central Computer and Telecommunications Agency) desarrolle una propuesta para el eficiente y efectivo (en términos financieros) uso de los recursos de tecnologías de la información. Esto resultó en ITIL.

El 1º de abril de 2001 la CCTA se fusiona con la OGC (Office of Government Commerce) que es actualmente el "dueño" de ITIL. El Objetivo de la OGC es ayudar a sus clientes del sector público británico a actualizar sus actividades y mejorar sus servicios mediante el buen uso de TI y otras herramientas. La OGC estimula el uso de "buenas prácticas" en muchas áreas (ej. administración de proyectos, administración de Servicios de TI, etc.) y publica libros escritos por expertos británicos e internacionales.

ITIL fue en sus orígenes una biblioteca de más de 40 volúmenes, que incluían las mejores prácticas de TI. En la actualidad, es más que un conjunto de libros, habiéndose convertido en la base de actuación, ampliamente aceptada, para las empresas de TI.

El marco de trabajo de ITIL provee una detallada descripción de un número de prácticas importantes en TI, con exhaustivas listas de chequeos, tareas, procedimientos y responsabilidades que pueden ser utilizados a la medida de las necesidades de cualquier organización. Estas prácticas están definidas como procesos, cubriendo la mayoría de las actividades de las organizaciones de servicios de tecnologías de la información. Su amplia cobertura en publicaciones permite referirse a

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

ella regularmente y proponer nuevos objetivos de mejoras para la organización. La organización puede crecer y madurar a través de su uso.

ITIL, considerado el mejor enfoque de la Gestión de Servicios de TI, no dicta cómo la organización debe ser estructurada, sino que define inteligentemente las relaciones entre las actividades en los procesos que son relevantes en cualquier organización. El marco de trabajo que propone ITIL permite compartir experiencias entre diferentes organizaciones estableciendo un lenguaje común.

Existen numerosos marcos de trabajo para Gestión de Servicios de TI basados en ITIL desarrollados por organizaciones comerciales. Esta es una de las razones por las cuales ITIL se ha convertido en el estándar “de facto” para describir los procesos fundamentales en Gestión de Servicios de TI. Se refiere a ITIL como “mejores prácticas”, si bien el término se ha cambiado últimamente por “buenas prácticas”.

Desde sus primeras publicaciones, ITIL ha estado a disposición del público, lo que significa que cualquier organización puede utilizar el marco de trabajo desarrollado. Organizaciones como entidades públicas locales y centrales, compañías energéticas, entidades de servicios públicos, entidades comerciales, financieras e industriales han implementado estas “buenas prácticas”. El marco de trabajo definido por ITIL puede ser utilizado por grandes, pequeñas y medianas empresas.

En mayo de 2007 salió al mercado ITIL V3 que incluye cinco libros principales donde se establecían 26 procesos:

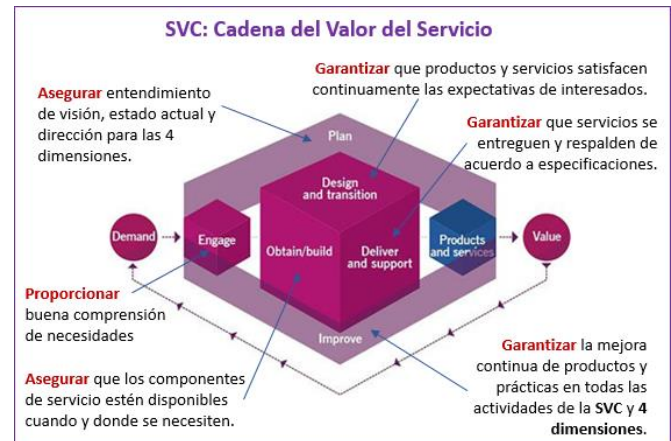
- Estrategia de Servicio (Service Strategy)
- Diseño del Servicio (Service Design)
- Transición del Servicio (Service Transition)
- Operación del Servicio (Service Operation)
- Mejora Continua del Servicio (Continual Service Improvement)

El objetivo principal de esta versión fue centrarse en el ciclo de vida del servicio y alinear las TI con el negocio.

En febrero de 2022 surge ITIL 4 que cambia a un enfoque ágil, utilizando un modelo de cuatro dimensiones para mostrar las perspectivas que son relevantes componentes para lo que denomina

Sistema de Valor del Servicio (SVS):

- **Organizaciones y Personas:** Esta dimensión de ITSM tiene como alcance los aspectos organizacionales y recursos humanos en una empresa.
- **Información y Tecnología:** Esta dimensión comprende todos los elementos técnicos que forman parte de la oferta de servicios.
- **Socios y Proveedores:** Dimensión que tiene como alcance las relaciones que tiene una empresa con otras empresas involucradas de alguna forma en la co-creación de valor.
- **Flujos de Valor y Procesos:** Esta dimensión abarca las actividades y métricas necesarias para lograr de manera consistente a los resultados esperados.

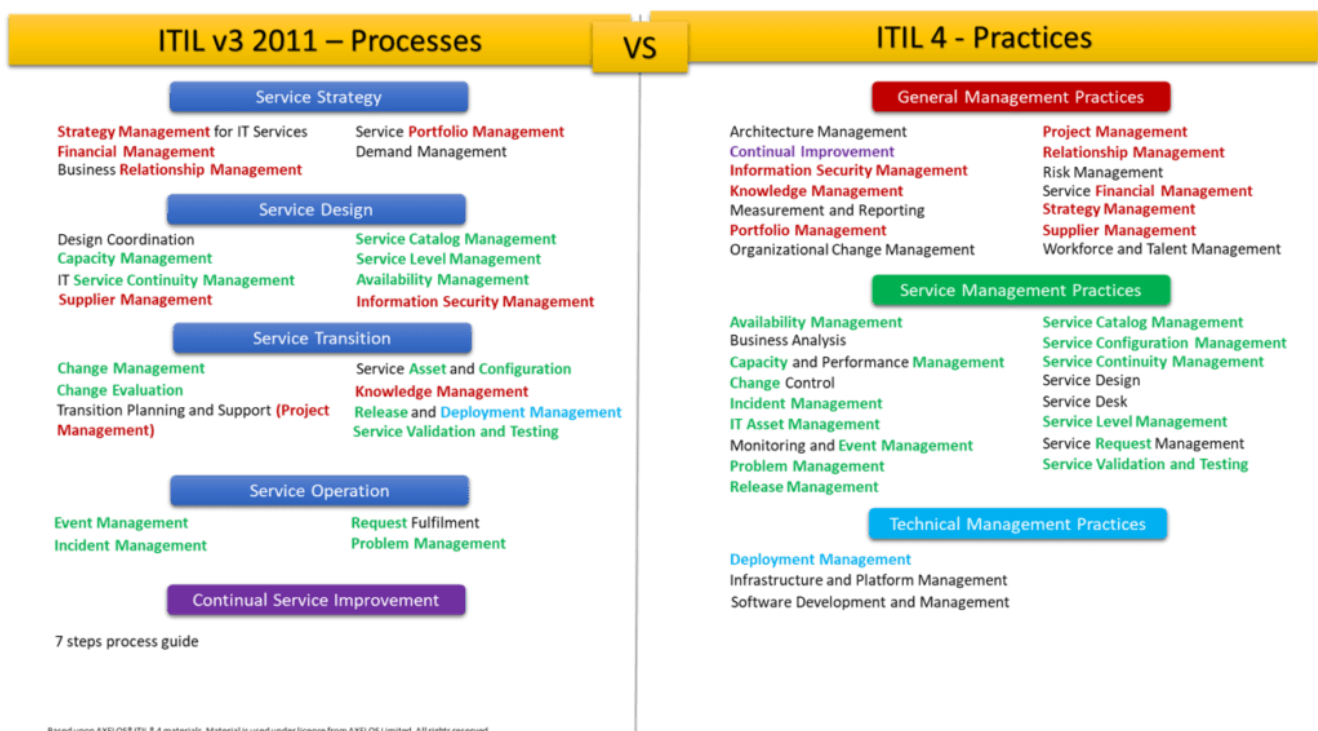
ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

ITIL 4 utiliza «procesos» para gestionar los servicios de TI denominándolos «prácticas».

Las prácticas de ITIL 4 comparten el mismo valor e importancia que los procesos actuales de ITIL v3, pero tienen una visión holística de las formas de trabajo permitida por la incorporación de elementos como la cultura, la tecnología, la información y la gestión de datos. El SVS incluye 34 prácticas que son conjuntos de recursos organizacionales para realizar un trabajo o lograr un objetivo. ITIL 4 cuenta con 34 prácticas agrupadas en 3 categorías:

1. Prácticas generales de gestión (14): aquellas que vienen del mundo empresarial y de la gestión propia del negocio.
2. Prácticas de gestión de servicios de TI (17): en este grupo encontraremos las prácticas que han sido desarrolladas para la gestión de servicios de TI (ITSM).
3. Prácticas de gestión técnica (3): este grupo de prácticas han sido tomadas de los dominios netamente tecnológicos.

La relación entre los procesos de ITIL v3 e ITIL 4 puede verse en el siguiente cuadro:



ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****PRÁCTICAS DE ITIL 4**

Prácticas de Gestión General	Prácticas de Gestión de Servicio	Prácticas de Gestión Técnica
- Gestión de estrategia - Gestión de portfolio - Gestión de arquitectura - Gestión financiera de servicios - Gestión de personal y talento - Mejora continua - Medición e informes - Gestión de riesgos - Gestión de la seguridad y de la información - Gestión del conocimiento - Gestión del cambio organizacional - Gestión de proyectos - Gestión de las relaciones - Gestión de suministros	- Análisis de negocio - Gestión del catálogo de servicios - Diseño de servicios - Gestión del nivel de servicio - Gestión de la disponibilidad - Gestión de capacidad y rendimiento - Gestión de la continuidad del servicio - Gestión y monitorización de eventos - Asistencia al cliente - Gestión de incidentes - Gestión de solicitudes de servicio - Gestión de problemas - Gestión de versiones - Control de cambios - Validación y pruebas del servicio - Gestión de la configuración del servicio - Gestión de activos de TI	- Gestión de la implementación - Gestión de infraestructura y plataformas - Desarrollo y gestión de software

Haremos mención de las prácticas más relevantes para en relación a la Gestión de Riesgos trabajada anteriormente y a optimización para la administración de los recursos mencionada en la introducción de esta Unidad.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****GESTIÓN DE INCIDENTES**

ITIL 4 define a un incidente como *"una interrupción no planificada de un servicio o la reducción de la calidad de un servicio."*

No existe una monitorización de los incidentes, sino que son informados por diversas fuentes tales como usuarios, soporte técnico, entre otros. Cuando las interrupciones de servicio o la reducción de su calidad son monitorizadas, ITIL las denomina *eventos* y son tratados por la Gestión de Eventos que veremos más adelante.

El objetivo del proceso de gestión de incidentes en ITIL es minimizar el impacto negativo de los incidentes mediante la restauración del funcionamiento normal del servicio lo más rápidamente que sea posible.

Los incidentes pueden afectar a todo el procedimiento, a un usuario o incluso a la totalidad de la organización, por eso es importante disponer de un sistema eficiente que se encargue de minimizar sus consecuencias.

La velocidad de recuperación es la máxima prioridad en esta práctica. Eso significa pueden abordarse soluciones temporales en lugar de soluciones permanentes para optimizar el tiempo de respuesta.

En relación a la Gestión de Riesgos, la comunicación del incidente por parte del usuario es el disparador que da la alerta de la materialización de un riesgo que debería haber sido identificado. Las soluciones temporales y permanentes son los planes de contingencia y recuperación que deben ser activados. En caso de que el incidente afecte a procesos críticos de la organización probablemente se deba activar el Plan de Continuidad de Negocio.

ACTIVIDADES DE LA GESTIÓN DE INCIDENTES**1. Registro**

- **La admisión del trámite del incidente:** el Centro de Servicios debe ser capaz de evaluar en primera instancia si el servicio requerido se incluye en el acuerdo de nivel de servicio (SLA) del cliente y en caso contrario reenviarlo a una autoridad competente.
- **Comprobación de que ese incidente aún no ha sido registrado:** es moneda corriente que más de un usuario notifique el mismo incidente y por lo tanto deben evitarse duplicaciones innecesarias.
- **Asignación de referencia:** se le asigna una referencia que identificará unívocamente al incidente, tanto en los procesos internos como en las comunicaciones con el cliente.
- **Registro inicial:** se registra la información básica necesaria para el procesamiento del incidente (hora, descripción del incidente, sistemas afectados, etc.).
- **Información de apoyo:** se incluirá cualquier información relevante para la resolución del incidente que puede ser solicitada al cliente a través de un formulario específico, o que pueda ser obtenida de la propia base de datos de configuración del sistema (CMDB) que

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

interrelaciona los elementos de configuración (CI) o activos de TI presentes en el servicio tales como hardware, software, documentación, entre otros.

- **Notificación del incidente:** en los casos en que el incidente pueda afectar a otros usuarios estos deben ser notificados para que conozcan cómo este incidente puede afectar su flujo habitual de trabajo.

2. Clasificación

El proceso de clasificación debe implementar, al menos, los siguientes pasos:

- **Categorización:** se asigna una categoría (que puede estar a su vez subdividida en más niveles) dependiendo del tipo de incidente o del grupo de trabajo responsable de su resolución. Se identifican los servicios afectados por el incidente.
- **Establecimiento del nivel de prioridad:** Es muy común que existan múltiples incidentes concurrentes por lo que es necesario determinar, con criterios predefinidos, un nivel de prioridad para la resolución de los mismos.

El nivel de prioridad se basa esencialmente en dos parámetros:

Impacto: determina la importancia del incidente dependiendo de cómo éste afecta a los procesos de negocio y/o del número de usuarios afectados.

Urgencia: depende del tiempo máximo de demora que acepte el cliente para la resolución del incidente y/o el nivel de servicio acordado en el SLA

- **Asignación de recursos:** Es frecuente que el Centro de Servicios no sea capaz de resolver en primera instancia un incidente y para ello deba recurrir a un especialista o a algún superior que pueda tomar decisiones que se escapen de su responsabilidad. A este proceso se le denomina escalado. Básicamente hay dos tipos diferentes de escalado:

Escalado funcional: Se requiere el apoyo de un especialista de más alto nivel para resolver el problema.

Escalado jerárquico: Debemos acudir a un responsable de mayor autoridad para tomar decisiones que se escapen de las atribuciones asignadas a ese nivel, como, por ejemplo, asignar más recursos para la resolución de un incidente específico.

- **Monitorización del estado y tiempo de respuesta esperado:** se asocia un estado al incidente (por ejemplo: registrado, activo, suspendido, resuelto, cerrado) y se estima el tiempo de resolución del incidente en base al SLA correspondiente y la prioridad.

3. **Análisis, Resolución y Cierre:** En primera instancia se examina el incidente con ayuda de la KB (Base de Conocimiento del sistema de gestión de conocimiento) para determinar si se puede identificar con algún incidente ya resuelto y aplicar el procedimiento asignado. Si la resolución del incidente se escapa de las posibilidades del Centro de Servicios éste redirecciona el mismo a un nivel superior para su investigación por los expertos asignados. Si estos expertos no son capaces de resolver el incidente se seguirán los protocolos de escalado predeterminados.

Durante todo el ciclo de vida del incidente se debe actualizar la información almacenada en las correspondientes bases de datos para que los agentes implicados dispongan de cumplida información sobre el estado del mismo.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

Cuando se haya solucionado el incidente se:

1. Confirma con los usuarios la solución satisfactoria del mismo.
2. Incorpora el proceso de resolución a la base de conocimiento (KB).
3. Actualiza la información en la CMDB sobre CI implicados en el incidente.
4. Cierra el incidente.

MÉTRICAS ASOCIADAS:

KPI	Descripción
Cantidad de incidentes repetidos	Cantidad de incidentes repetidos (con métodos para su resolución ya conocidos)
Incidentes resueltos a distancia	Cantidad de incidentes resueltos a distancia por el Service Desk (p.ej. sin acudir al lugar del usuario)
Cantidad de escalados	Cantidad de escalados de incidentes no resueltos en el tiempo acordado
Cantidad de incidentes	Cantidad de incidentes registrados por el Service Desk agrupados por categorías
Tiempo de resolución de incidente	Tiempo medio para resolver un incidente, agrupados por categorías
Tasa de Resolución de Primera Llamada	Porcentaje de incidentes resueltos en el Service Desk durante la primera llamada, agrupados por categorías
Resolución dentro del SLA	Porcentaje de incidentes resueltos durante el tiempo acordado en el SLA, agrupados por categorías
Esfuerzo de resolución de incidente	Promedio de esfuerzo de trabajo para resolver Incidentes, agrupados por categorías

La gestión de incidentes no acaba con el cierre del mismo, ya que uno de los enfoques de ITIL4 es la mejora continua, buscando reiterativamente soluciones de prevención que impidan que surjan problemas o incidentes que afecten a la calidad del servicio.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****GESTIÓN DE SOLICITUDES DE SERVICIO**

Es la encargada de atender las solicitudes de los usuarios proporcionándoles información y acceso rápido a los servicios estándar de la organización TI.

Una solicitud puede englobar: Solicitudes de información o consejo, solicitudes de cambios estándar, solicitudes de acceso a servicios IT.

La Gestión de Solicitudes de Servicio proporciona al departamento comercial un acceso rápido y efectivo a servicios estándar. Esto mejora su productividad, la calidad de los servicios comerciales y los propios productos, reduce la burocracia asociada al proceso de solicitud de acceso a servicios nuevos o ya existentes, reduciendo asimismo los costos, incrementa el nivel de control sobre los servicios al centralizar la concesión de acceso a los mismos, reduce costos al centralizar la negociación con proveedores respecto al acceso a los servicios, y también al reducir el costo del soporte.

ACTIVIDADES DE LA GESTIÓN DE SOLICITUDES DE SERVICIO

- 1. Selección de solicitudes.** Los usuarios, a través de las herramientas destinadas a tal fin, emiten sus peticiones conforme a una serie de tipologías predefinidas.
- 2. Aprobación financiera de la solicitud.** Dado que la mayoría de solicitudes tienen implicaciones financieras, se considera su costo y se decide si tramitar la solicitud o no.
- 3. Tramitación.** La solicitud es cursada por la persona o personas adecuadas según cada caso para su resolución.
- 4. Cierre.** Tras notificar al Centro de Servicios y comprobar desde aquél que el usuario ha quedado conforme con la gestión se procede a cerrarla.

MÉTRICAS ASOCIADAS:

KPI	Descripción
Solicitudes de Servicio procesadas	Cantidad total de solicitudes de servicio
Estado de Solicitudes de Servicio	Desglose de solicitudes de servicio en cada etapa: registrada, aprobada, cerrada, etc.
Solicitudes Pendientes	Tamaño de la lista de solicitudes de servicios pendientes
Tiempo de atención de solicitudes	Promedio de tiempo de atención de las solicitudes de servicio por tipo
Solicitudes finalizadas con éxito	Cantidad y Porcentaje de Solicitudes de Servicio completadas de acuerdo a los tiempos acordados
Costo promedio	Costo promedio de Solicitudes de Servicio por Tipo de Solicitud
Nivel de Satisfacción del cliente	Nivel de Satisfacción del cliente con el tratamiento de la solicitud del servicio, medida por encuestas de satisfacción

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****CENTRO DE SERVICIOS DE TI**

Para la Gestión de Incidentes como para la Gestión de Solicitudes, los usuarios finales son derivados a un único punto de contacto (o primera línea de soporte), el Centro de Servicios de TI. Se basa en varios principios y prácticas clave para garantizar la prestación eficiente y efectiva de servicios de soporte.

En principio los Centros de Servicios de TI deben brindar canales de acceso, que pueden ser:

- llamadas telefónicas, que pueden incluir respuesta de voz interactiva (IVR), conferencias telefónicas, reconocimiento de voz y otros
- portales de servicios y aplicaciones móviles, respaldados por catálogos de solicitudes y servicios, y bases de conocimientos
- chat, a través de chat en vivo y chatbots
- correo electrónico para registro y actualización, y para encuestas de seguimiento y confirmaciones.
- Los centros de servicios sin cita son cada vez más frecuentes en algunos sectores, p. ej. educación superior, donde hay altos picos de actividad que exigen presencia física
- Mensajes de texto y de redes sociales, que son útiles para notificaciones en caso de incidentes importantes y para contactar a grupos específicos de partes interesadas, pero también se pueden utilizar para permitir que los usuarios soliciten asistencia.
- Foros de discusión y redes sociales públicas y corporativas para contactar al proveedor de servicios y para soporte entre pares.

En algunos casos, el centro de servicios de TI es un equipo que trabaja en un solo lugar, centralizada. En otros casos, una mesa de servicio virtual permite a los agentes trabajar desde múltiples ubicaciones, dispersas geográficamente con soluciones basadas en la nube.

Un centro de servicios de TI requiere tecnologías de apoyo:

- Sistemas de telefonía inteligente, que incorporan integración de telefonía-computadora, IVR y distribución automática de llamadas
- Software de Gestión de Servicios de TI (ITSM) que proporcionan una suite completa de herramientas para la gestión de servicios de TI, incluyendo la gestión de incidentes, la gestión de solicitudes de servicio, entre otras. Estas herramientas permiten registrar, priorizar y gestionar eficientemente todos los tickets de servicio. Entre estas plataformas se pueden mencionar ServiceNow, BMC Remedy y Jira Service Desk
- Herramientas de Automatización de Procesos: Integradas a la plataforma de conocimiento para automatizar tareas repetitivas y flujos de trabajo que ayudan a acelerar la resolución de problemas y mejoran la eficiencia operativa. Entre ellas Microsoft Power Automate y Zapier
- Software de Gestión del Conocimiento: Las bases de datos de conocimiento (KB) integradas en las plataformas de ITSM o software independiente, como Confluence o SharePoint, permiten al personal del Service Desk acceder a documentación detallada, guías de solución de problemas y artículos de ayuda para resolver problemas de manera rápida y eficiente.
- Herramientas de Colaboración y Comunicación: Las herramientas de colaboración en equipo, como Microsoft Teams, Slack o herramientas de chat en tiempo real integradas en

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

plataformas de ITSM, permiten una comunicación rápida y eficiente entre los miembros del equipo del Service Desk, así como con otros grupos de soporte técnico y usuarios finales.

- **Portal de Autoservicio para Usuarios Finales:** que permiten a los usuarios finales registrar incidentes y solicitudes de servicio, seguir el progreso de sus tickets, acceder a documentación de soporte y buscar soluciones a problemas comunes de manera autónoma.

Otra herramienta muy importante, y que hemos mencionado anteriormente, es la Base de Datos de Configuraciones (CMDB), un repositorio centralizado de los elementos de configuración: hardware, software, documentación y personas que forman parte de la infraestructura del cliente y de los servicios que se prestan. La Gestión de Incidentes y de Solicitudes pueden asociar estos elementos al registro para mayor información a la hora de su resolución.

Es frecuente que el Centro de Servicios de TI no sea capaz de resolver en primera instancia un incidente y para ello deba recurrir a un especialista o a algún superior que pueda tomar decisiones que se escapan de su responsabilidad. A este proceso se le denomina escalado. Básicamente hay dos tipos diferentes de escalado:

- **Escalado funcional:** Se requiere el apoyo de un especialista de más alto nivel para resolver el problema. En general denominado segunda línea de soporte que puede ser personal abocado a la Gestión de Problemas que veremos más adelante.
- **Escalado jerárquico:** Debemos acudir a un responsable de mayor autoridad para tomar decisiones que se escapan de las atribuciones asignadas a ese nivel, como, por ejemplo, asignar más recursos para la resolución de un incidente específico.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información****GESTIÓN Y MONITORIZACIÓN DE EVENTOS**

El propósito de la práctica de gestión y monitorización de eventos es observar sistemáticamente los servicios y componentes del servicio, y registrar e informar cambios de estado seleccionados identificados como *eventos*. Esta práctica identifica y prioriza la infraestructura, los servicios, los procesos comerciales y los eventos de seguridad de la información, y establece la respuesta adecuada a esos eventos, incluida la respuesta a las condiciones que podrían conducir a posibles fallas o incidentes.

En este contexto, un *evento* es cualquier cambio de estado que tenga importancia para la gestión de un servicio u otro elemento de configuración (CI). Los eventos generalmente se reconocen a través de notificaciones creadas por un servicio de TI, CI o herramienta de monitoreo.

No todos los eventos tienen el mismo significado ni requieren la misma respuesta. Los eventos a menudo se clasifican como:

- Informativos: informativos no requieren acción en el momento en que se identifican, pero el análisis de los datos recopilados de ellos en una fecha posterior puede revelar información que puede ser beneficiosa a la Gestión de Problemas que veremos más adelante.
- De advertencia: permiten que se tomen medidas antes de que la empresa experimente un impacto negativo, es un disparador para Estrategias de Tratamiento en la Gestión de Riesgos
- Excepciones: indican que se ha identificado una infracción a una norma establecida. Los eventos de excepción requieren acción, son los disparadores de Planes de Contingencia en la Gestión de Riesgos.

Esta práctica es altamente interactiva con otras prácticas que participan en la cadena de valor del servicio. Por ejemplo, algunos eventos calificarán como incidente. En este caso, la acción de control correcta será iniciar actividad en la práctica de Gestión de Incidentes. Los eventos repetidos que muestran un desempeño fuera de los niveles deseados pueden ser evidencia de un problema potencial, que iniciaría la actividad en la práctica de Gestión de Problemas. Para algunos eventos, la respuesta correcta es iniciar un cambio, involucrando la práctica de Control de Cambios.

Aunque el trabajo de esta práctica, una vez implementado, está altamente automatizado, la intervención humana aún es necesaria y, de hecho, es esencial. Para la definición de estrategias de monitoreo y umbrales específicos y criterios de evaluación, puede ayudar a incorporar una amplia gama de perspectivas, incluida la infraestructura, las aplicaciones, los propietarios de servicios, la gestión del nivel de servicio y la representación de las prácticas relacionadas con la garantía.

Vista las características de las actividades de la Gestión y Monitorización de Eventos, no pueden ser realizadas por el Centro de Servicios de TI, en general las mismas están asignadas a personal técnico con competencias específicas que conforman una segunda o tercera línea de soporte. Los roles y responsabilidades deben estar claramente definidos, y cada persona o grupo debe tener un acceso fácil y oportuno a la información necesaria para desempeñar su rol. La automatización es clave para el éxito de la supervisión y la gestión de eventos. Algunos componentes de servicio vienen equipados con capacidades integradas de monitoreo y generación de informes que se pueden configurar para satisfacer las necesidades de la práctica, pero a veces es necesario implementar y configurar herramientas de monitoreo especialmente diseñadas.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

La Gestión y Monitorización de Eventos, además de detectar y notificar los sucesos, se encarga de clasificarlos y dimensionar su impacto en el servicio. Llegado el caso, se ocupa también de documentar el evento y derivarlo al proceso correspondiente para que tome medidas.

Los aspectos claves en la Gestión de Eventos son una buena monitorización y efectivos sistemas de control. Encontramos dos tipos de herramientas:

- **de monitorización activa.** Se comprueban los CI uno a uno para verificar su estado y disponibilidad. Si detecta excepciones, la herramienta de monitorización genera una alerta y la envía al equipo o mecanismo de control asignado.
- **de monitorización pasiva.** Detectan y correlacionan alertas operacionales y quedan registradas asociadas al mismo CI (por ejemplo: logs de acceso).

También deben usarse herramientas automatizadas para la correlación de eventos. Estas funciones pueden proporcionarse mediante herramientas de supervisión u otras herramientas, como los sistemas de flujo de trabajo ITSM. Puede haber un gran volumen de datos generados por esta práctica, pero sin políticas y estrategias claras sobre cómo limitar, filtrar y usar estos datos, no tendrán ningún valor.

ACTIVIDADES DEL LA GESTIÓN Y MONITORIZACIÓN DE EVENTOS

1. **Detección del disparador del evento:** El proceso se inicia cuando ocurre el suceso
2. **Notificación del evento:** al equipo responsable de su resolución o gestión
3. **Detección y filtrado del evento:** La notificación llega a un agente o herramienta de gestión que la lee e interpreta el suceso con el fin de determinar si merece mayor atención o no.
4. **Clasificación del evento:** asigna una categoría y un nivel de prioridad.
5. **Correlación:** Se analiza si existen eventos similares, así como la importancia del evento en sí mismo y se decide si es necesario tomar medidas.
6. **Selección de la respuesta:** Se ponen en marcha los mecanismos necesarios para dar respuesta al evento. Se eligen las soluciones a adoptar.
7. **Revisión de acciones y cierre:** Se revisan las excepciones o eventos importantes para determinar si se han tratado correctamente. Se cierra el proceso de Gestión de Eventos.

MÉTRICAS ASOCIADAS:

KPI	Descripción
Eventos clasificados	Número de eventos, por categorías y por impacto Número y porcentaje de cada tipo de evento, por plataforma o aplicación
Intervención en eventos	Número y porcentaje de eventos que requirieron de intervención humana y cómo fue esa intervención
Escalado para resolución	Número y porcentaje de eventos que desembocaron en el registro de una nueva incidente o solicitud de cambio

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

Eventos reiterados	Número y porcentaje de eventos ocasionados por problemas ya existentes o errores conocidos
Eventos duplicados	Número y porcentaje de eventos repetidos o duplicados. Esto es relevante para optimizar la función de Correlación
Eventos por problemas de capacidad	Número y porcentaje de eventos relacionados con problemas de rendimiento
Eventos por problemas de disponibilidad	Número y porcentaje de eventos que indican futuros problemas de disponibilidad
Ratio de Incidentes por Eventos	Número y ratio de eventos por comparación al número de incidentes

GESTIÓN DE PROBLEMAS

ITIL 4 define a un problema como “una causa o causa potencial, de uno o más incidentes”.

Es decir, no hay que confundir incidentes con problemas.

- Los incidentes son elementos reparables (break-fix) que causan un impacto negativo en las personas y, como tales, deben resolverse para restaurar el funcionamiento normal del trabajo
- Los problemas causan incidentes o eventos. Deben analizarse e investigarse para que se puedan identificar soluciones temporales o definitivas que reduzcan el número y el impacto de futuros incidentes o eventos.

La Gestión de Problemas puede ser:

- **Reactiva:** Notificado el incidente o evento que no tiene una solución temporal o definitiva conocida, lo analiza para descubrir su causa y proponer soluciones.
- **Proactiva:** Basándose en los incidentes registrados o monitorizando la calidad de la infraestructura TI y analizando su configuración con el objetivo de prevenir incidentes o eventos con las mismas características antes de que estos ocurran. Cuando algún tipo de incidente se convierte en recurrente o tiene un fuerte impacto en la infraestructura TI es la función de la Gestión de Problemas el determinar sus causas y encontrar posibles soluciones definitivas.

Sin embargo, la Gestión de Problemas no realiza la implementación de cambios, para esto existe una práctica específica: El Control de Cambios, con la que debe interactuar.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

ACTIVIDADES DE LA GESTIÓN DE PROBLEMAS

1. **Identificación y Registro:** Todas las áreas de la infraestructura TI deben colaborar con la Gestión de Problemas para identificar problemas reales y potenciales informando a ésta de cualquier síntoma que pueda ser señal de un deterioro en el servicio TI.

El Problema debe ser registrado, ya sea completando el registro del incidente, en el caso de la gestión de problemas proactiva, o realizando el registro inicial una vez analizados los incidentes recurrentes. En cualquier caso el registro del problema deberá contener, entre otra, información sobre: los elementos de configuración (**CI**) implicados, causas del problema, síntomas asociados, soluciones temporales, servicios involucrados, niveles de urgencia, prioridad e impacto, estado: activo, error conocido, cerrado.

2. **Clasificación y Asignación de recursos:** La clasificación del problema engloba desde las características generales de éste, tales como si es un problema de hardware o software, qué áreas funcionales se ven afectadas y detalles sobre los diferentes **CI** involucrados en el mismo. Al igual que en la Gestión de Incidentes la prioridad puede cambiar en el curso del ciclo de vida del problema, por ejemplo, si se encuentra una solución temporal al mismo que reduce considerablemente su impacto. Una vez clasificado y determinada su prioridad se deben de asignar los recursos necesarios para su solución. Estos recursos deben ser suficientes para asegurar que los problemas asociados son tratados eficazmente y así minimizar su impacto en la infraestructura TI.

3. **Análisis y diagnóstico:** Se deben determinar las causas del problema y proporcionar soluciones temporales a la Gestión de Incidentes para minimizar el impacto del problema hasta que se implementen los cambios necesarios que lo resuelvan definitivamente.

Es esencial tener en cuenta que no siempre el origen del problema es un error de hardware o software. Puede que esté causado por: errores de procedimiento, documentación incorrecta, falta de coordinación entre diferentes áreas. Es también posible que la causa del problema sea un "bug" bien conocido de alguna de las aplicaciones utilizadas. Por lo tanto, es conveniente establecer contacto directo con el entorno de desarrollo, en caso de aplicaciones desarrolladas internamente, o investigar en Internet información sobre errores conocidos aplicables al problema en cuestión. Una vez determinadas las causas del problema éste se convierte en un *Error Conocido* y se remite al *Control de Errores* para su posterior procesamiento.

2. **Control de Errores:** Registra los errores conocidos y propone soluciones a los mismos mediante Solicitudes de cambio (**RFC**) que son enviadas al Control de Cambios. Una vez efectuado el cambio, efectúa la **PIR** de los mismos en estrecha colaboración con el Control de Cambios.

Análisis y Solución: Se deben investigar diferentes soluciones para el error evaluando en cada momento el posible impacto de las mismas en la infraestructura TI, los costos asociados y sus consecuencias sobre los **SLA**. En algunos casos, en los que el impacto del problema puede tener consecuencias graves en la calidad del servicio, pueden emitirse una **RFC** de emergencia para su procesamiento urgente por El Control de Cambios.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

3. **Revisión Post Implementación y Cierre:** antes de dar el problema por resuelto y cambiar su estado a “cerrado” se debe analizar el resultado de la implementación de la RFC elevado al Control de Cambios mediante las PIR. Si los resultados de esta PIR son los deseados y se pueden cerrar todos los incidentes relacionados con este problema se considera concluido el proceso y se emiten los informes correspondientes.

MÉTRICAS ASOCIADAS

El objetivo de la Gestión de Problemas no es otro que el de mejorar el funcionamiento de la infraestructura TI y para evaluar su eficacia es imprescindible realizar un continuo seguimiento de los procesos relacionados y evaluar su rendimiento.

En particular una buena gestión de problemas debe traducirse en una:

- Disminución del número de incidentes y una más rápida resolución de los mismos.
- Mayor eficacia en la resolución de problemas.
- Gestión proactiva que permita identificar problemas potenciales antes de que estos se manifiesten o provoquen una seria degradación de la calidad del servicio.

KPI	Descripción
Cantidad de problemas	Cantidad de problemas registrados agrupados por categorías
Tiempo de resolución de problemas	Tiempo medio para resolver problemas, agrupados por categorías
Cantidad de incidentes por problema	Cantidad media de incidentes vinculados al mismo problema antes de identificar el problema
Cantidad de incidentes por problema conocido	Cantidad media de incidentes vinculados al mismo problema después de identificar el problema
Tiempo hasta la identificación del problema	Tiempo medio transcurrido entre la primera aparición de un incidente y la identificación de la raíz del problema
Esfuerzo de resolución de problemas	Tiempo medio de esfuerzo de trabajo para resolver problemas agrupados por categorías

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN

Unidad 2: Administración de Recursos en Áreas de Sistemas de Información

CONTROL DE CAMBIOS

Lo único inmutable es el cambio.

Si bien el cambio suele ser fuente de problemas y no debe hacerse sin evaluar bien sus consecuencias puede resultar mucho más peligroso el estancamiento en servicios y tecnologías desactualizados.

El principal objetivo del Control de Cambios es la evaluación y planificación del proceso de cambio para asegurar que, si éste se lleva a cabo, se haga de la forma más eficiente, siguiendo los procedimientos establecidos y asegurando en todo momento la calidad y continuidad del servicio TI.

El Control de Cambios debe trabajar para asegurar que los cambios están justificados, se llevan a cabo sin perjuicio de la calidad del servicio TI, están convenientemente registrados, clasificados y documentados, han sido cuidadosamente testeados en un entorno de prueba, se ven reflejados en la **CMDB** y pueden deshacerse mediante planes de "retirada del cambio" (back-outs) en caso de un incorrecto funcionamiento tras su implementación.

CONCEPTOS BÁSICOS

Gestor de Cambios: es el responsable del proceso del cambio. En grandes organizaciones puede disponer de un equipo de asesores específicos para cada una de las diferentes áreas.

Consejo Asesor de Cambios (CAB): es un órgano interno, presidido por el Gestor de Cambios, formado principalmente por representantes de las principales áreas de la gestión de servicios TI. Puede incorporar consultores externos, representantes de los grupos de usuarios y representantes de los principales proveedores de software y hardware. Puede formarse un **ECAB** (Comité de emergencia), en casos de necesidad.

ACTIVIDADES DEL CONTROL DE CAMBIOS:

1. **Registro:** El origen de una solicitud de cambios (**RFC**) puede ser de muy distinta índole
 - **Gestión de Problemas:** propone soluciones a errores conocidos. En la mayoría de los casos esta solución acarrea un cambio en la infraestructura TI que debe ser registrado con información para que pueda ser evaluada la pertinencia del proceso.
 - **Gestión de Solicitudes de Servicios:** puede requerir cambios de la infraestructura TI. En este caso es importante coordinar todo el proceso con las Gestiones de Capacidad, Disponibilidad y Niveles de Servicio para asegurar que estos cambios cumplen las expectativas previstas y no deterioran la calidad de los otros servicios prestados.
 - **Estrategia empresarial:** la dirección puede decidir una redirección estratégica que puede afectar, por ejemplo, a los niveles de servicio ofrecidos, y que por regla general requieren de cambios de hardware, software y/o procedimientos.
 - **Actualizaciones de software de terceros:** los proveedores pueden dejar de soportar versiones anteriores de paquetes de software o introducir nuevas versiones con grandes mejoras que recomienden la actualización.
 - **Imperativo legal:** un cambio de legislación puede exigir cambios en la infraestructura TI.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

- **Otros:** en principio cualquier empleado, cliente o proveedor puede sugerir mejoras en los servicios que pueden requerir cambios en la infraestructura.

Independientemente de su origen, el correcto registro inicial de una **RFC** requerirá de: Fecha de recepción, identificador único, identificador del error conocido asociado (dado el caso), descripción del cambio propuesto: motivación, propósito, **CI** involucrados, estimación de recursos necesarios para la implementación, tiempo estimado y un estado que inicialmente será el de "registrado". Este registro deberá ser actualizado con toda la información generada durante el proceso para permitir un detallado seguimiento del mismo desde su aprobación hasta la evaluación final y cierre. Esta información debe incluir al menos: los cambios de estado a: "aceptado", "rechazado", "implementado", etc., las fechas de estos cambios, evaluación realizada por la Gestión del Cambio, prioridad y categoría (dependiendo del impacto y de la urgencia), especificación de los planes de "back-out", recursos asignados, fecha de implementación, descripción del plan de implementación, que deberá seguir la Gestión de Versiones, cronograma, revisión post-implementación (**PIR**), evaluación final y fecha de cierre.

2. **Aceptación o rechazo:** Una **RFC** puede ser simplemente rechazada si se considera que el cambio no está justificado o se puede solicitar su modificación si se considera que algunos aspectos de la misma son susceptibles de mejora o mayor definición. En estos casos la **RFC** debe ser devuelta al departamento o persona que la generó. La aceptación del cambio no implica su posterior aprobación por el **CAB** y es sólo indicación de que se justifica su implementación.
3. **Clasificación:** Establecer la prioridad y categoría dependiendo de la urgencia y el impacto de la misma. La prioridad determinará la importancia relativa de esta RFC respecto a otras RFC pendientes y será el dato relevante para establecer el calendario de cambios a realizar.
4. **Aprobación y Planificación:** Para su aprobación, el cambio se debe evaluar minuciosamente ya que un cambio menor puede derivar en una reacción en cadena con resultados catastróficos. Es imprescindible disponer de planes de "back-out" que permitan la recuperación de la última configuración estable antes del cambio.
5. **Implementación del cambio:** En ITIL 4, El Control de Cambios se adapta para ser más ágil y permitir cambios más rápidos y frecuentes, al tiempo que se mantiene el control y la mitigación de riesgos. Promueve la adopción de prácticas de entrega continua y despliegue continuo para permitir la entrega rápida y confiable de cambios en los servicios de TI. Esto implica la automatización de procesos de construcción, prueba y despliegue para acelerar la entrega de cambios al entorno de producción de manera segura y confiable, en estrecha relación con la Gestión de Versiones y la Gestión de la Configuración de Servicios de TI. Los clientes y proveedores no deben percibir el cambio como algo inesperado. Es función tanto del Control de Cambios como del Centro de Servicios de TI mantener informados a los usuarios de los futuros cambios y hacerles partícipes del mismo escuchando sus sugerencias, comunicando las ventajas asociadas, aclarando sus dudas y dando soporte cuando ello sea necesario: la percepción de mejora debe ser compartida por usuarios y clientes.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

6. Evaluación del cambio: Antes de proceder al cierre del cambio, es necesario verificar que ha sido positivo para el servicio. Aunque El Control de Cambios es la encargada de emitir el dictamen final, es la evaluación del servicio la que ha de proporcionar a ésta los informes.

Si la evaluación final determina que el proceso y los resultados han sido satisfactorios se procederá al cierre de la **RFC** y toda la información se incluirá en la **PIR** asociada.

Cambios de Emergencia: Cualquier interrupción del servicio de alto impacto, ya sea por el número de usuarios afectados o porque se han visto involucrados sistemas o servicios críticos para la organización, debe encontrar una respuesta inmediata. Estos procedimientos a seguir en estos casos deben estar debidamente previstos, estableciendo protocolos que impliquen reuniones urgentes del CAB y/o ECAB o decisiones Gestor del Cambio si es imposible demorar la resolución del problema o éste sucede durante periodos de inactividad.

Es esencial que al cierre del cambio de emergencia se disponga de la misma información de la que tendríamos tras un cambio normal. Si esto no fuera así se podrían provocar situaciones de cambios futuros incompatibles, configuraciones registradas incorrectas, etc. que serían fuente de nuevos incidentes y problemas.

MÉTRICAS ASOCIADAS

KPI	Descripción
Cantidad de cambios solicitados	Cantidad de RFC evaluados por el CAB
Cantidad de reuniones de CAB	Cantidad de reuniones de CAB con información estadística asociada: número de asistentes, duración, número de cambios aprobados por reunión, etc.
Tasa de aceptación de cambios	Cantidad de RFC aceptadas vs. rechazadas
Número de cambios clasificados	Número de cambios realizados clasificados por impacto y prioridad y filtrados temporalmente
Tiempo para autorización para cambios	Tiempo medio transcurrido desde la solicitud de una RFC al Control de Cambios hasta la autorización para el cambio
Tiempo medio del cambio	Tiempo medio transcurrido desde la autorización de una RFC hasta su cierre dependiendo del impacto y la prioridad.
Porcentaje de cambios exitosos	Porcentaje de cambios exitosos en primera instancia, segunda instancia, etc.
Cantidad de Back-outs	Numero de back-outs con una detallada explicación de los mismos.
Porcentaje de cambios cerrados sin incidentes ulteriores	Cantidad de cambios que no han requerido la ejecución de planes de back-out
Incidentes asociados a cambios realizados	Cantidad de incidentes detectadas asociadas a cambios realizados después de su cierre.
Cantidad de cambios urgentes	Cantidad de cambios urgentes evaluados por el ECAB (Consejo Consultor para Cambios de Emergencia)
Evaluaciones post-implementación	Cantidad de PIR realizadas posteriores a la implementación de un cambio

GESTIÓN DE LA CONFIGURACIÓN DEL SERVICIO Y GESTIÓN DE ACTIVOS DE TI

Es esencial conocer en detalle la infraestructura TI de nuestras organizaciones para obtener el mayor provecho de la misma.

En ITIL V3 estas gestiones estaban unidas, la separación entre la Gestión de la Configuración del Servicio y la Gestión de Activos en ITIL 4 permite una mayor claridad y enfoque en las actividades y objetivos específicos de cada práctica, lo que facilita una gestión más efectiva de la infraestructura de TI y los recursos asociados. Si bien pueden superponerse en algunas áreas, cada una de estas prácticas tiene su propio conjunto de actividades y responsabilidades para garantizar el éxito en la gestión de servicios de TI.

La Gestión de la Configuración del Servicio se centra en el mantenimiento de la Base de Datos de Gestión de la Configuración (CMDB) y la gestión de los elementos de configuración (CI). Su objetivo principal es proporcionar una visión precisa y actualizada de la infraestructura de TI y los servicios asociados, incluyendo la relación entre los diferentes CI y su estado en un momento dado.

La Gestión de Activos se centra en la gestión de los activos de TI a lo largo de su ciclo de vida completo, desde la adquisición hasta la disposición. Su objetivo principal es maximizar el valor de los activos de TI y optimizar su rendimiento, costo y riesgo asociado.

ACTIVIDADES DE LA GESTIÓN DE LA CONFIGURACIÓN DEL SERVICIO

1. **Identificación de Elementos de Configuración (CI):** Identificar y definir los elementos de configuración (CI) que forman parte de la infraestructura de TI y los servicios asociados. Esto puede incluir hardware, software, documentación, personas, procesos y cualquier otro componente necesario para entregar y soportar los servicios de TI.
2. **Registro y Clasificación de CI:** Registrar formalmente cada CI en la Base de Datos de Gestión de la Configuración (CMDB) y clasificarlos según su tipo, función y relación con otros CI. Esto ayuda a mantener un inventario completo y organizado de todos los componentes de la infraestructura de TI y los servicios asociados.
3. **Control de la Configuración:** Establecer controles y procedimientos para gestionar cambios en la configuración de los CI a lo largo de su ciclo de vida. Esto implica autorizar, registrar, evaluar y aprobar cambios de configuración, así como gestionar la implementación de cambios de manera controlada y coordinada.
4. **Auditoría y Verificación de CI:** Realizar auditorías regulares y verificaciones de la precisión y la integridad de la información de configuración en la CMDB. Esto ayuda a garantizar que la CMDB refleje con precisión el estado actual de la infraestructura de TI y los servicios asociados, y que se mantenga actualizada en todo momento.
5. **Gestión de Relaciones y Dependencias:** Identificar y gestionar las relaciones y dependencias entre los diferentes CI en la CMDB. Esto implica comprender cómo los cambios en un CI pueden afectar a otros CI y a los servicios de TI en general, y tomar medidas para minimizar los impactos negativos.
6. **Reportes y Análisis de Configuración:** Generar informes y análisis periódicos sobre la configuración de la infraestructura de TI y los servicios asociados. Esto incluye métricas de

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

rendimiento, tendencias de cambio, cumplimiento de políticas y requisitos regulatorios, y cualquier otro dato relevante para la gestión de la configuración del servicio.

7. **Gestión de Versiones y Baselines:** Gestionar versiones y baselines de configuración para mantener un registro histórico de cambios y facilitar la reversión a estados anteriores si es necesario. Esto ayuda a garantizar la integridad y la consistencia de la configuración a lo largo del tiempo y a mitigar los riesgos asociados con los cambios.

ACTIVIDADES DE LA GESTIÓN DE ACTIVOS DE TI

1. **Planificación Estratégica de Activos:** Desarrollar una estrategia de gestión de activos que alinee los recursos de TI con los objetivos del negocio. Esto implica establecer políticas, objetivos y procedimientos para la gestión de activos, así como definir roles y responsabilidades dentro de la organización.
2. **Adquisición y Aprovisionamiento:** Identificar las necesidades de activos de TI de la organización y adquirirlos de manera eficiente y efectiva. Esto implica evaluar proveedores, negociar contratos, realizar compras y gestionar el proceso de aprovisionamiento desde la solicitud inicial hasta la entrega y aceptación del activo.
3. **Seguimiento y Control de Activos:** Realizar un seguimiento detallado de todos los activos de TI a lo largo de su ciclo de vida, desde la adquisición hasta la disposición. Esto incluye mantener registros actualizados de activos, realizar inventarios regulares, verificar la ubicación y el estado de los activos, y garantizar el cumplimiento de los acuerdos de licencia y contratos.
4. **Gestión de Licencias de Software:** Gestionar de manera proactiva las licencias de software para garantizar el cumplimiento legal y optimizar los costos asociados con el software. Esto implica mantener registros precisos de licencias, controlar el uso de software, gestionar renovaciones y actualizar políticas de licencias según sea necesario.
5. **Optimización de Costos:** Identificar oportunidades para optimizar los costos asociados con los activos de TI y maximizar el retorno de la inversión. Esto puede incluir la consolidación de activos, la negociación de contratos favorables, la eliminación de activos obsoletos o subutilizados, y la implementación de prácticas de gestión de activos más eficientes.
6. **Disposición de Activos al Final de su Vida Útil:** Planificar y gestionar la disposición final de los activos de TI al final de su vida útil. Esto implica asegurar la eliminación segura y responsable de los activos, cumplir con los requisitos legales y regulatorios, y minimizar cualquier impacto ambiental negativo asociado con la disposición de activos.

MÉTRICAS ASOCIADAS:

KPI	Descripción
Frecuencia de verificación	Frecuencia de verificaciones físicas del contenido de la CMDB
Duración de verificación	Duración promedio de verificaciones físicas del contenido de la CMDB
Esfuerzo para verificaciones	Promedio de esfuerzo de trabajo para verificaciones físicas del contenido de la CMDB

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

Cubiertas CMS	Porcentaje de elementos de configuración cuyos datos están incluidos en la CMDB
Actualización automática	Porcentaje de elementos de configuración cuyos datos en la CMDB se actualizan automáticamente
Cantidad de desvíos	Número de ocasiones en las auditorías de configuración detectaron incorrecciones en el contenido de la CMDB
CI involucrados en incidentes	Cantidad de CI que han estado involucrados en incidentes
Configuraciones no autorizadas	Cantidad de configuraciones detectadas en controles y auditorías que no fueron autorizadas o no cuentan con licencias
Costos asociados	Costos asociados a las actividades de Gestión de la Configuración y Activos de Servicio

GESTIÓN DE VERSIONES

La Gestión de Versiones es la encargada del control de calidad de todo el software y hardware instalado en el entorno de producción.

Colabora estrechamente con el Control de Cambios, las Gestiones de Configuración del Servicio y de Activos de TI para asegurar que toda la información relativa a las nuevas versiones se integra adecuadamente en la **CMDB** de forma que ésta se halle correctamente actualizada y ofrezca una imagen real de la configuración de la infraestructura TI.

La Gestión de Versiones también debe mantener actualizada la Biblioteca de Medios Definitivo (**DML**), donde se guardan copias de todo el software en producción, y los Recambios Definitivos (**DS**), donde se almacenan piezas de repuesto y documentación para la rápida reparación de problemas de hardware en el entorno de producción.

CONCEPTOS BÁSICOS

Versiónes: Una versión es un nuevo grupo de **CIs** o un grupo de CIs modificados que han sido validados para su instalación en el entorno de producción. Las especificaciones funcionales y técnicas de una versión están determinadas en la **RFC** correspondiente.

Las versiones pueden clasificarse, según su impacto en la infraestructura TI, en:

- **Versiónes mayores:** que representan importantes despliegue de software y hardware y que introducen modificaciones importantes en la funcionalidad, características técnicas, etc.
- **Versiónes menores:** que suelen implicar la corrección de varios errores conocidos puntuales y que a menudo son modificaciones que vienen a implementar, de una manera correctamente documentada, soluciones de emergencia.
- **Versiónes de emergencia:** modificaciones que reparan de forma rápida un error conocido. Como pueden llegar a existir múltiples versiones es conveniente definir una referencia o código que los identifique unívocamente. El sistema universalmente aceptado es:

Versiónes mayores: 1.0, 2.0, etc.

Versiónes menores: 1.1, 1.2, 1.3, etc.

Versiónes de emergencia: 1.1.1, 1.1.2, etc

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

Biblioteca de Medios Definitivos (DML): debe contener copia de todo el software instalado en el entorno TI. Esto incluye no solo sistemas operativos y aplicaciones sino también controladores de dispositivos y documentación asociada. Debe contener el histórico completo de versiones de un mismo software para proporcionar la versión necesaria en caso de que se deban implementar los planes de back-out. Debe ser almacenada en un entorno seguro y es conveniente que se realicen back-up periódicos.

Almacén de **Recambios Definitivos (DS):** contiene piezas de repuesto para los CIs en el entorno de producción.

MÉTRICAS ASOCIADAS:

KPI	Descripción
Cantidad de versiones	Cantidad de versiones desplegadas en el área de producción de TI, agrupadas en versiones mayores, menores o de emergencia.
Cantidad de back-outs	Cantidad de versiones que fueron revertidas y razones
Cantidad de incidentes	Cantidad de incidentes asociadas a nuevas versiones
Cumplimiento de plazos	Cumplimiento de los plazos previstos para cada despliegue
Duración de Versiones Mayores	Duración media de versiones mayores, desde su autorización hasta su finalización
Proporción de versiones con despliegue automático	Proporción de nuevas versiones distribuidas automáticamente
Utilización de recursos	Asignación de recursos para el despliegue de versiones
Disponibilidad del Servicio	Disponibilidad del servicio durante y tras el proceso de lanzamiento de la nueva versión.

ANEXOS

ANEXO I: PROCESO RELACIONADO AL OBJETIVO GESTIONAR RIESGOS DE COBIT 2019

Recopilar datos: Integrar la gestión del riesgo empresarial relacionado con la TI con la gestión del riesgo empresarial global, y equilibrar los costos y beneficios de la gestión del riesgo empresarial relacionado con las TI.

1. Establecer y mantener un método para la recogida, clasificación y análisis de datos relacionados con el riesgo de TI.
2. Registrar datos relevantes y significativos relacionados con los riesgos de TI en el entorno operativo interno y externo de la empresa.
3. Adoptar o definir una taxonomía de riesgo para las definiciones consistentes de escenarios de riesgo y categorías de impacto y probabilidad.
4. Registrar datos de eventos, incidentes o problemas de riesgo que han causado o podrían causar impacto en el negocio conforme a las categorías de impacto definidas en la taxonomía de riesgo., incidentes, problemas e investigaciones.
5. Estudiar y analizar los datos históricos de riesgo de TI y de pérdidas experimentadas a partir de datos y tendencias externos disponibles, homólogos de la industria a través de logs de eventos de la industria, bases de datos, y acuerdos de la industria, para la publicación común de eventos.
6. Para clases de eventos similares, organizar los datos recopilados y resaltar los factores causantes.
7. Determinar las condiciones específicas que existieron o estuvieron ausentes cuando tuvieron lugar los eventos de riesgo y la forma en que las condiciones afectaron a la frecuencia del evento y la magnitud de la pérdida.
8. Realizar un análisis periódico de eventos y factores de riesgo para identificar riesgos nuevos o emergentes y para mejorar el entendimiento de los factores de riesgo internos y externos asociados.

Analizar el riesgo. Desarrollar una visión fundamentada del riesgo de TI vigente, que soporte las decisiones de riesgo.

1. Definir el alcance adecuado de los esfuerzos en análisis de riesgos, considerando todos los factores de riesgo y/o la criticidad de los activos para el negocio.
2. Crear y actualizar regularmente los escenarios de riesgo de TI; las exposiciones a pérdidas relacionadas con TI; y los escenarios relacionados con el riesgo reputacional, incluidos escenarios compuestos de tipos de amenazas y eventos en cascada y/o coincidentes. Desarrollar previsiones para actividades de control específicas y capacidades de detección.
3. Estimar la frecuencia (o probabilidad) y la magnitud de la pérdida o ganancia asociada con escenarios de riesgos de TI. Tener en cuenta todos los factores de riesgo aplicables y evaluar controles operativos conocidos.
4. Comparar el riesgo actual (exposición a pérdidas de TI) con el apetito al riesgo y la tolerancia de riesgo aceptable. Identificar el riesgo inaceptable o elevado.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

5. Proponer respuestas al riesgo para riesgos que excedan el apetito al riesgo y los niveles de tolerancia.
6. Especificar los requisitos de alto nivel para los proyectos o programas que implementarán las respuestas a los riesgos seleccionados. Identificar los requisitos y expectativas para los controles clave adecuados a fin de proporcionar respuestas de mitigación de riesgos.
7. Validar el análisis de riesgo y los resultados del análisis de impacto del negocio (BIA) antes de usarlos en la toma de decisiones. Confirmar que el análisis se corresponde con los requisitos empresariales y comprobar que los sesgos de las estimaciones se calibraron y analizaron de forma adecuada.
8. Analizar el costo/beneficio de las posibles opciones de respuesta al riesgo, como evitar, reducir/mitigar, transferir/compartir y aceptar y explotar/aprovechar. Confirmar la respuesta óptima al riesgo.

Mantener un perfil de riesgo. Mantener un inventario de los riesgos conocidos y los atributos de riesgo, incluidos la frecuencia esperada, impacto potencial y respuestas. Documentar los recursos, capacidades y actividades de control actuales relacionados con elementos de riesgo.

1. Hacer un inventario de los procesos de negocio y documentar su dependencia con los procesos de gestión de servicios de TI y los recursos de infraestructura de TI. Identificar el personal de apoyo, aplicaciones, infraestructura, instalaciones, registros manuales críticos, contratistas, proveedores, y terceros.
2. Determinar y acordar qué servicios de TI y recursos de infraestructura de TI son esenciales para sostener el funcionamiento de los procesos de negocio. Analizar las dependencias e identificar los eslabones débiles.
3. Agregar los escenarios de riesgos actuales por categoría, línea de negocio y área funcional.
4. Capturar regularmente toda la información del perfil de riesgo y consolidarla en un perfil de riesgo agregado.
5. Capturar información sobre el estado del plan de acción de riesgos para su inclusión en el perfil de riesgo de TI de la empresa.
6. Con base en todos los datos del perfil de riesgo, definir un conjunto de indicadores de riesgo que permitan una identificación y monitorización rápida del riesgo actual y las tendencias de riesgo.

Articular el riesgo. Comunicar de manera oportuna información sobre el estado actual de las exposiciones y oportunidades relacionadas con TI a todas las partes interesadas requeridas para obtener una respuesta apropiada.

1. Informar sobre los resultados del análisis de riesgo a todas las partes interesadas afectadas en términos y formatos útiles para soportar las decisiones empresariales. Siempre que sea posible, incluir las probabilidades y rangos de pérdidas o ganancias, junto con los niveles de confianza, para permitir que la gerencia haga balance del retorno del riesgo.
2. Proporcionar a los responsables de la toma de decisiones la comprensión de los escenarios más probables y peores, exposiciones a pérdidas de TI y consideraciones significativas de reputación, legales y regulatorias, o cualquier otra categoría de impacto conforme a la taxonomía de riesgos. Se presenta la información actualizada a todos los responsables de los activos y a las gerencias en formato comprensible para la toma de decisiones.

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

3. Informar sobre el perfil de riesgo actual a todas las partes interesadas. Incluir información sobre la eficacia del proceso de gestión de riesgos, eficacia del control, brechas, inconsistencias, redundancias, estado de remediación y sus impactos en el perfil de riesgo.
4. De forma periódica, en áreas con riesgos relativos y capacidades de riesgo similares, identificar oportunidades relacionadas con TI que permitirían la aceptación de un riesgo mayor y un mayor crecimiento y retorno.
5. Revisar los resultados de las evaluaciones objetivas de terceros y revisiones de auditoría interna y de aseguramiento de la calidad. Incluirlos en el perfil de riesgo. Revisar las brechas identificadas y las exposiciones de pérdidas relacionadas con TI para determinar la necesidad de un análisis de riesgos adicional.

Definir un portafolio con acciones de gestión de riesgos. Gestionar las oportunidades para reducir el riesgo a un nivel aceptable como un portafolio.

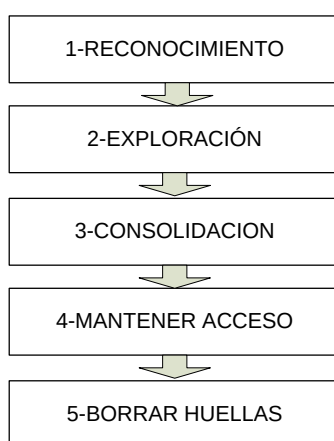
1. Mantener un inventario de las actividades de control que se han implantado para mitigar el riesgo y que permiten que se tomen riesgos alineados con el apetito y la tolerancia al riesgo. Clasificar las actividades de control y asignarlas a escenarios de riesgos de TI específicos y escenarios de riesgos de TI agregados.
2. Determinar si cada entidad organizativa monitoriza el riesgo y acepta la responsabilidad de actuar dentro de los niveles de tolerancia individuales y del portafolio. Cumple con esta actividad, con el departamento de gestión integral de riesgos que se encarga de toda la organización.
3. Definir un conjunto de propuestas de proyectos equilibrada diseñada para reducir el riesgo y/o proyectos que permitan oportunidades empresariales estratégicas, con consideración de los costes, beneficios, efecto en el perfil de riesgo actual y en las regulaciones.

Responder al riesgo. Responder de manera oportuna a eventos de riesgo materializados con medidas eficaces para limitar la magnitud de las pérdidas.

1. Preparar, mantener y probar planes que documenten los pasos específicos que deben darse cuando un evento de riesgo pudiera causar un incidente significativo de desarrollo u operativo con un impacto grave para el negocio. Asegurar que los planes incluyan vías de escalamiento en la empresa.
2. Aplicar el plan de respuesta adecuado para minimizar el impacto cuando ocurren incidentes de riesgo.
3. Clasificar los incidentes y comparar las exposiciones a pérdidas relacionadas con TI con los umbrales de tolerancia al riesgo. Comunicar los impactos de negocio a los responsables de la toma de decisiones como parte del reporte y actualización del perfil de riesgo.
4. Examinar eventos adversos/pérdidas y oportunidades del pasado no consideradas y determinar las causas raíz.
5. Comunicar la causa raíz, requisitos adicionales de respuestas al riesgo y mejoras del proceso a los responsables de la toma de decisiones correspondientes. Asegurar que la causa, requisitos de respuesta y mejora del proceso se incluyan en los procesos de gobierno del riesgo.

ANEXO II: ETAPAS DE UN CIBERATAQUE

Para explicar las amenazas y vulnerabilidades en Ciberseguridad desarrollaremos un esquema para comprender en qué consiste un ataque informático. En la descripción de cada fase mencionaremos herramientas utilizadas por los atacantes. Es importante recordar que el uso de estas herramientas puede ser ilegal y está sujeto a restricciones legales y éticas. Siempre es recomendable utilizar estas herramientas de manera ética y legal, con el permiso explícito del propietario del sistema o red objetivo.



Fase 1: Reconocimiento. Esta etapa involucra la obtención de información con respecto a una potencial víctima que puede ser una persona u organización. Se selecciona el objetivo identificando sistemas, redes o datos vulnerables que serán el objetivo del ataque.

Fase 2: Exploración. En esta segunda etapa se utiliza la información obtenida en la fase 1 para sondear el blanco y tratar de obtener información sobre el sistema víctima como direcciones IP, nombres de host, datos de autenticación, sistemas operativos, servicios en ejecución entre otros.

Las herramientas utilizadas en estas dos fases son:

- Herramientas de Escaneo de Red: Nmap, Masscan, Zmap
- Herramientas de Recopilación de Información: theHarvester, Maltego, Shodan
- Herramientas de Reconocimiento Activo: Recon-ng, Metasploit
- Herramientas de Ingeniería Social: Social Engineering Toolkit (SET), Gophish
- Herramientas de Escaneo de Vulnerabilidades: Nessus, OpenVAS, Qualys

Fase 3: Consolidación. En esta instancia comienza a materializarse el ataque a través de la explotación de las vulnerabilidades y defectos del sistema (Flaw exploitation) descubiertos durante las fases de reconocimiento y exploración.

La consolidación de un ataque puede comprender la elevación de privilegios, el movimiento lateral, es decir, la propagación a través de la red de la víctima para comprometer otros sistemas y

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

expandir el alcance del ataque y la exfiltración de datos (recolección y transmisión) o la utilización de credenciales robadas o vulnerabilidades adicionales para comprometer otros sistemas en la red.

Algunas de las técnicas que el atacante puede utilizar son ataques de Buffer Overflow, de Denial of Service (DoS), Distributed Denial of Service (DDoS), Password filtering y Session hijacking.

Las herramientas generalmente utilizadas en esta fase son:

Herramientas de Explotación de Vulnerabilidades: Metasploit, ExploitDB, SQLMap

Herramientas de Exfiltración de Datos: Cobalt Strike, Mimikatz, Empire

Herramientas de Escalada de Privilegios: PowerSploit, Sudo-Killer, BeRoot

Fase 4: Mantener del Acceso. Una vez que el atacante ha conseguido acceder al sistema, buscará implantar herramientas que le permitan volver a acceder en el futuro desde cualquier lugar donde tenga acceso a Internet. El atacante mantiene el acceso al sistema comprometido para garantizar la persistencia del ataque y manipula o elimina rastros para evitar ser detectado por los sistemas de seguridad

Las herramientas generalmente utilizadas en esta fase son:

Backdoors: Netcat (nc), Meterpreter (parte de Metasploit), Cobalt Strike

Rootkits: RootkitHunter, chkrootkit, Windows Rootkit Arsenal,

Trojanos y RATs (Remote Access Trojans): DarkComet, NanoCore

Persistencia en el Sistema: Scheduled Tasks (Tareas Programadas), Registro (Registry), Service Installation (Instalación de Servicios)

Fase 5: Borrar huellas. Una vez que el atacante logró obtener y mantener el acceso al sistema, intentará borrar todas las huellas que fue dejando durante la intrusión para evitar ser detectado por el profesional de seguridad o los administradores de la red. En consecuencia, buscará eliminar archivos de registro, archivos de configuración y otras pistas de la actividad del atacante para evitar ser detectado.

Para mitigar ataques informáticos las organizaciones implementan centros de operaciones de seguridad (SOC) o contratan personal que realice monitoreo y responda a los posibles incidentes.

Las herramientas que se utilizan en la actualidad para mitigar los ataques informáticos son:

IDS: Sistema de detección de Intrusiones: un dispositivo de monitoreo pasivo que detecta amenazas potenciales y genera alertas

IPS: Sistema de prevención de intrusiones fueron desarrollados para no sólo encargarse de la búsqueda de actividad maliciosa, sino también intentar detenerla. Estos dispositivos proactivos de

ADMINISTRACIÓN DE SISTEMAS DE INFORMACIÓN**Unidad 2: Administración de Recursos en Áreas de Sistemas de Información**

seguridad de red, monitorizan el tráfico de la misma de forma continua, así como las todas las actividades de un entorno TI. El IPS controla de acceso en una red informática, protegiendo a los sistemas computacionales de abusos y ataques. Situando sistemas de detección en las vías de tráfico, los IPS resuelven ambigüedades en las tareas de monitorizar de forma pasiva las redes de computadoras. Para combatir las actividades potencialmente maliciosas, este software es capaz de tomar decisiones sobre el control de acceso, basándose en los contenidos del tráfico -en lugar de puertos o direcciones IP-. Por ello, debemos reconocer que los IPS representan una importante mejora respecto a las tradicionales tecnologías de cortafuegos.